CASE STUDY

Major Cloud Security Incidents: The Public Record, 2011 to 2026

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carry the weight of a cloud incident are rarely the ones who wrote the headline. They are the bank customers whose Social Security numbers sat in a storage bucket, the wireless subscribers whose call records were copied from a workspace on a third-party cloud platform, the State Department analysts who noticed a strange application reading their mail, the managed service providers who spent late October and early November 2026 re-authorizing every Microsoft 365 tenant they back up, and the administrators at small companies who were told, again and again, to rotate every secret they had. This study follows that record from the first well-documented credential incidents at a consumer cloud service in 2012 to the multi-tenant application compromises of October and November 2026.

Read end to end, the primary record tells a different story from the one most coverage told. The incidents that made "the cloud was breached" headlines were, in the providers' and responders' own investigations, mostly failures in the band that every major provider says always belongs to the customer: identities, access policy, configuration and data. Mandiant found no evidence that the 2024 Snowflake campaign came from a breach of Snowflake's enterprise environment; every incident Mandiant responded to traced back to compromised customer credentials, most of them exposed by infostealers, used against instances that did not require MFA (**Confirmed** [53]). The regulator that fined Capital One cited the bank's own risk assessment before its cloud migration (**Confirmed** [9]). Google's threat intelligence team said the 2025 Salesloft Drift theft did not stem from a core Salesforce vulnerability (**Confirmed** [68]).

That is only half of the record. The other half is a short list of failures no customer setting could have stopped, and they are the most serious. In 2023 a China-based actor Microsoft calls Storm-0558 used a Microsoft consumer signing key created in 2016 to forge tokens that enterprise Exchange Online accepted, and reached the mailboxes of 22 organizations and over 500 individuals (**Confirmed** [47]). The Cyber Safety Review Board called the intrusion preventable, blamed "a cascade of security failures at Microsoft", and found that Microsoft

still did not know how the key was obtained (**Confirmed** [47]). The first customer to spot it could do so only because it had paid for a premium logging tier and had built its own baseline of mailbox access (**Confirmed** [47][30]). Cross-tenant flaws at Azure Cosmos DB in 2021, Entra ID in 2025 and Cloudflare Containers in 2026 were found by researchers and bug bounty reports rather than by attackers, as far as the record shows (**Confirmed** [18][70][75]).

From 2021 onward the dominant pattern is neither storage misconfiguration nor provider compromise. It is the theft of a non-human identity that many tenants trust: an OAuth app (Salesloft Drift, 2025), a support-system service account (Okta, 2023), the customer secrets a CI platform held for its users (CircleCI, 2022), a cross-account integration role (Qubole, 2026), or a multi-tenant backup application (ConnectWise Cloud Backup, 2026). One stolen secret in that layer reaches hundreds or thousands of tenants at once (**Inferred** from [68][37][27][80][77]).

> Evidence grade: incident facts come from the affected companies' own statements, SEC filings, regulators, CISA and the CSRB, and the responders' primary reports, and are **Confirmed**. Exposure discoveries known only from the finder's write-up, and press accounts of 2026 events whose primaries did not render, are **Reported** and attributed. Where this study draws its own conclusion, it is labelled **Inferred**.

Key facts at a glance

Field	Value
Period covered	2011 (as an industry link the CSRB relays) and 2012 (first primary opened) to 9 November 2026 [47][1][81][83]
Earliest primary in the record	Dropbox, 31 July 2012: passwords stolen from other websites used to sign in to a small number of accounts [1]
Largest single regulator penalty in the record	OCC, $80 million civil money penalty against Capital One, 6 August 2020 [9]
Capital One, 2019	Access on 22 and 23 March 2019; about 100 million people in the US and 6 million in Canada; about 140,000 US SSNs, 80,000 linked bank account numbers and about 1 million Canadian SINs [8]
Storm-0558, 2023	Forged tokens from 15 May 2023; 22 organizations and over 500 individuals (CSRB); about 60,000 emails taken from State alone [29][47]
Snowflake customer campaign, 2024	UNC5537; about 165 organizations notified from 22 May 2024; at least 79.7 percent of the accounts used had prior credential exposure [53]
Widest multi-tenant targeting	Storm-0940 used ConnectWise application identities to attempt sign-ins to more than 2,250 tenants, October 2026 [77]
Government reviews	CSRB on Lapsus$ and related groups (10 August 2023) and on the Summer 2023 Exchange Online intrusion (dated 20 March 2024, released 2 April 2024) [33][47][49]
Provider defaults that changed after incidents	S3 Block Public Access on by default (April 2023); IMDSv2 as an account default (March 2024); Azure mandatory MFA (October 2024 and early 2025); Snowflake single-factor password retirement (September 2025 to October 2026, estimated) [88][12][63][71]
Largest non-attack event	CrowdStrike Channel File 291, 19 July 2024: about 8.5 million Windows devices, not a cyberattack [58][59]
ATT&CK objects bound	G0016 APT29, G1004 LAPSUS$, G1015 Scattered Spider, C0024, C0027, C0059 and others in the MITRE mappings Part [97]
Actors with no ATT&CK object	Storm-0558, UNC5537, UNC6395, Storm-0940, Storm-3168 [97]

Key findings

- **The customer band is where most incidents sat.** AWS, Microsoft and Google all place identities, access policy and data on the customer in every service model, and Google says outright that customers "always remain responsible for their access policies and data" (**Confirmed** [89][90][91]). The Snowflake, Salesloft Drift, Uber 2016 and Capital One incidents all sit in that band (**Inferred** from [53][68][3][9]).
- **The worst provider failure was found by a customer with a premium licence.** State Department detected Storm-0558 on 15 and 16 June 2023 with a custom rule over the MailItemsAccessed log, available to it only because it had bought G5 licensing (**Confirmed** [47]). Victims without that tier could not reconstruct past activity (**Confirmed** [47]). Microsoft made email-access logs part of the standard tier from September 2023 (**Confirmed** [31]).

- **Microsoft's root-cause story was corrected late.** Microsoft's 6 September 2023 post named an April 2021 crash dump as the most probable path to the key; Microsoft told the Board in November 2023 that the post was inaccurate but corrected it only on 12 March 2024, and the CSRB found Microsoft did not know how or when the key was obtained (**Confirmed** [34][47]).
- **Non-human identities are the recurring root cause.** OAuth tokens (Salesloft Drift), a service account saved in a personal browser profile (Okta), customer CI secrets reached through one engineer's stolen session (CircleCI), a credential exposed through a Docker image build (Codecov), an overly permissive SAS token in a public repository (Microsoft, 2023), and multi-tenant application credentials (ConnectWise, Todyl's 2026 cases) recur at least as often in the 2021 to 2026 record as a single user's password (**Confirmed** for each event [68][37][27][16][35][77][82]; the pattern is **Inferred**).
- **MFA gaps were exploited at every scale.** UNC5537's accounts had no MFA; Midnight Blizzard's sprayed test account had no MFA; Uber's 2022 contractor approved a push after repeated prompts; the CSRB found SMS and voice MFA defeated by SIM swapping (**Confirmed** [53][43][22][33]).
- **Delegated trust multiplies reach.** CISA warned in 2017 that IT service providers were targeted to reach their customers; in 2026 Storm-0940 used ConnectWise application identities against more than 2,250 tenants, and a separate operator used stolen app secrets and reached 27 organizations, with Partner Center and GDAP used to reach customer tenants (**Confirmed** [7][77][82]).
- **Regulators judged the customer's cloud governance.** The OCC fined Capital One over risk assessment before migration; the FTC's proposed Drizly order binds the CEO personally after two incidents involving GitHub: cloud login information posted there in 2018, and a 2020 breach through the corporate GitHub login; the SEC's 2023 rule made a material incident a four-business-day 8-K disclosure (**Confirmed** [9][26][32]).

Top recommendations

1. **Put phishing-resistant MFA on every human path, and remove passwords from non-human ones.** The CSRB recommended FIDO2 phishing-resistant passwordless MFA after Lapsus$, Snowflake's published schedule blocks password-only sign-in for all human users and moves legacy service users off passwords in August to October 2026 (estimated dates), and Microsoft enforces MFA on Azure portals and tools (**Confirmed** [33][71][63]).
2. **Inventory and shrink every app, token and integration role that other tenants trust you through, and that you trust others through.** Audit app-only permissions and consent grants, restrict connected-app scopes, rotate any secret found in exported data, and treat MSP multi-tenant apps and cross-account roles as privileged identities (**Confirmed** for Microsoft's app-governance guidance [43] and ConnectWise's re-authorization [78]; the remaining steps and the framing are **Inferred**).
3. **Make short-lived credentials the default.** Use IMDSv2 as the account default for new EC2 launches, and OIDC tokens rather than long-lived CI secrets, as CircleCI told every customer to do (**Confirmed** [12][27]).
4. **Log mailbox and API access, keep it, and baseline it.** Turn on the Purview audit events and CloudTrail, keep logs well beyond 90 days (AA23-193A recommends 12 months active and 18 months cold), and build the per-application baseline State Department spent three years building (**Confirmed** [30][87][47]).
5. **Bind sessions and watch for their reuse.** Bind admin sessions to network location, as Okta did after 2023, and alert when instance-role credentials are used outside the instance, as GuardDuty does

(**Confirmed** [37][93]).

6. **Plan for the provider that fails.** Treasury warned in 2023 that concentration on a few providers means one incident can affect many firms at once, and the largest availability event in this record, CrowdStrike's July 2024 update, came from a trusted vendor's update channel rather than an attacker (**Confirmed** [28][58]; the planning lesson is **Inferred**).

Scope and method

This study covers security incidents in public cloud infrastructure and software-as-a-service platforms from 2011 to November 2026, including incidents at identity providers, CI and developer platforms and MSP tooling whose impact reached customer cloud tenants. Ransomware against on-premises systems (The Ransomware Ecosystem), the Change Healthcare attack (Change Healthcare, 2024) and managed file transfer campaigns (Cl0p and file transfer) are summarized only where they touch cloud trust, and link to their home studies. It draws on the affected companies' own statements and SEC filings, the CSRB's two cloud-related reviews, CISA and FBI advisories, directives and alerts, the OCC, FTC, SEC and US Treasury, provider documentation from AWS, Microsoft, Google, Snowflake and Cloudflare, the responders' primary reports (Mandiant, Google Threat Intelligence Group, Microsoft Threat Intelligence, Wiz, Todyl), the CVE, NVD and KEV records, the live MITRE ATT&CK pages and the library's own data files. Every source was opened on 11 November 2026. The Intelligence Hub feed served as an index of recent events; its rows were used only to find primary links, and four 2026 rows backed only by secondary reporting were not taken from the feed; one of them, ASOS, appears once, graded Reported, from the trade-press article itself (**Inferred** [96]; **Reported** [85]). Quotations are kept to a few words.

Grade	Meaning
Confirmed	A primary source was opened: the affected organization, a regulator or government body, a provider's own documentation, a CVE or NVD record, the responder that investigated, or the MITRE record itself
Reported	Known only through a secondary source, such as a news article or a third party's own discovery write-up, whose claim the primary record does not repeat; the source is named
Demonstrated	A public reproduction exists. No item here is graded Demonstrated; no exploit material was opened or is described
Inferred	This study's own reasoning from the cited facts, labelled where it appears

A finder's write-up of an exposure it discovered (UpGuard's bucket reports) is graded Reported, because the data owner's statement was not opened. A researcher's own disclosure of a flaw it reported, where the provider's record or CVE agrees, is graded Confirmed. A responder's report on its own investigation is graded Confirmed for what it observed and carries the responder's attribution language as written: "assesses", "believes", "affiliated with".

Some events named in the wider record are not checked here, because no primary source for them could be opened: the 2014 Code Spaces destruction, the 2018 Tesla Kubernetes cryptojacking report, and the US Department of Justice's press releases and complaint in the Capital One case. They appear in this study only where an opened source carries them, and the gap is stated where it matters.

Tradecraft is described at the level the advisories use: technique names and ids. No command lines, queries or payload strings appear here.

Part 1: whose job is it? Shared responsibility as the providers state it

Every cloud incident in this record starts with the same question: was this the provider's control or the customer's? The three largest providers answer it in their own words, and their answers agree on the part that matters most.

- **AWS** frames the split as security "of" the cloud and security "in" the cloud. AWS runs the infrastructure, hardware, software, networking and facilities. On EC2 the customer owns guest operating system patching, data and encryption choices, IAM permissions and security group configuration; on abstracted services such as S3 the customer still manages data and access (**Confirmed** [89]).
- **Microsoft's** responsibility matrix lists customer data, configurations and settings, and identities and users as the customer's in on-premises, IaaS, PaaS and SaaS alike. Physical hosts, network and datacenter are Microsoft's from IaaS upward. The customer always keeps data, endpoints, accounts and access management, including RBAC, MFA and conditional access. Microsoft adds that "responsibility" is used in a governance sense and is not a legal conclusion (**Confirmed** [90]).
- **Google Cloud** says shared responsibility "stops short" and promotes "shared fate": secure blueprints, landing zones, a Risk Protection Program, Assured Workloads and Organization Policies. Customers "always remain responsible for their access policies and data"; in IaaS the customer holds most tasks, and in SaaS the customer still holds access controls and data (**Confirmed** [91]).

The common ground is the band that never moves to the provider: identity, access policy, configuration and data. This study uses that band as its first lens. The Snowflake 2024 and Salesloft Drift 2025 campaigns sit inside it; Storm-0558, the Cosmos DB notebook flaw and the Entra ID Actor token flaw sit outside it, in the provider's control plane, where no customer setting could have prevented them (**Inferred** from [89][90][91][53][68][47][18][70]).

The second lens is defaults. Responsibility on paper does not decide outcomes on its own: new S3 buckets blocked public access by default only from April 2023, IMDSv2 became an account-level default for new launches only in March 2024, and Snowflake's enforcement of MFA arrived in phases from September 2025 (**Confirmed** [88][12][71]). Customer fault and provider defaults are both part of the record (**Inferred**).

Part 2: the timeline

One row per incident, report or decision. Dates are the event date where the source gives one, otherwise the publication date. Most provider control changes and regulator actions are in Parts 4 and 5. Each year's wider record is in the chronicle series: 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025.

2011 to 2018: buckets, credentials and service providers

Date	Event	Actor, as the source names it	Grade	Source
2011	The RSA SecurID incident, which the CSRB says industry links to the same actor as Storm-0558 (along with Operation Aurora in 2009)	Industry attribution relayed by the CSRB	Reported	[47]
2012-07-31	Dropbox says usernames and passwords stolen from other websites were used to sign in to a small number of Dropbox accounts, and a stolen password opened an employee's Dropbox account holding a project document with user email addresses, which it believed caused spam; it announces optional two-factor authentication	Unnamed	Confirmed	[1]
2012 (theft); 2016-08-25 (reset)	Dropbox confirms a set of about 68 million email addresses with hashed and salted passwords is real and likely obtained in 2012, and resets passwords unchanged since mid-2012	Unnamed	Confirmed	[2]
2016-11 (learned); 2017-11 (disclosed)	Uber: intruders use an access key an engineer had posted on a code-sharing website to download unencrypted files from a third-party cloud provider: 25 million names and emails, 22 million names and phone numbers, 600,000 driver's license numbers; Uber pays them $100,000 through its bug bounty program; the year's accounts are in Chronicle 2016 and, for the 2017 disclosure, Chronicle 2017	Unnamed intruders	Confirmed (FTC, 2018-04-12)	[3]
2017-04-27 (revised 2018-12-20)	CISA TA17-117A: IT service providers targeted so their credentials and shared infrastructure reach customer environments; initial victims in IT, Energy, Healthcare and Public Health, Communications and Critical Manufacturing; PlugX (SOGU) and REDLEAVES named	Chinese actors associated with the MSS (2018 revision); APT10 named only through the reports the alert cites	Confirmed	[7]
2017-07-12	UpGuard reports a misconfigured S3 bucket run by Verizon vendor NICE Systems exposing names, addresses, account details and PINs of up to 14 million Verizon customers; a Verizon spokesperson puts it at 6 million	Exposure, no actor	Reported (UpGuard)	[4]
2017-09-17	UpGuard finds four publicly downloadable S3 buckets holding Accenture Cloud Platform credentials, keys, certificates and configuration; Accenture secures them the day after notification	Exposure, no actor	Reported (UpGuard)	[5]
2017-11-17	UpGuard reports three public S3 buckets of scraped internet posts, one with at least 1.8 billion posts over eight years, tied to CENTCOM and PACOM and built by a defunct contractor it calls VendorX	Exposure, no actor	Reported (UpGuard)	[6]
2018	The FTC alleges that Drizly cloud login information posted on GitHub was used for cryptomining (proposed FTC order, 2022)	Unnamed	Confirmed	[26]

2019 to 2021: Capital One, SolarWinds' cloud follow-on and the first cross-tenant flaws

Date	Event	Actor, as the source names it	Grade	Source
2019-03-22 to 2019-03-23	Capital One: an outside individual accesses data through a "configuration vulnerability"; an external researcher reports it on 2019-07-17 and Capital One determines the intrusion on 2019-07-19; the individual "was captured by the FBI"; the year's account is in Chronicle 2019	One individual	Confirmed	[8]
2019-12-05 to 2019-12-31	Microsoft: a change to a customer support case analytics database's network security group exposes the data; fixed after researcher Bob Diachenko's notification; no malicious use found; redaction missed some non-standard personal data	Exposure, no actor	Confirmed	[13]
2020	The FTC alleges that a breach through Drizly's corporate GitHub login exposed data on about 2.5 million consumers	Unnamed	Confirmed (FTC)	[26]
2020-08-06	OCC assesses an $80 million civil money penalty against Capital One and issues a cease and desist order for failing to establish effective risk assessment before moving significant IT operations to the public cloud	Regulator	Confirmed	[9]
2020-11	Earliest infostealer infection Mandiant later ties to a credential UNC5537 used against Snowflake customer accounts in 2024	Infostealer operators	Confirmed	[53]
2021-01-08	CISA AA21-008A on post-compromise activity in Microsoft cloud tenants after the SolarWinds compromise: forged SAML tokens, credentials added to service principals and applications, Graph API mailbox access	An APT actor (updated 15 April 2021: the SVR); ATT&CK records the campaign as C0024 SolarWinds Compromise by G0016 APT29 [94]; home study SolarWinds SUNBURST	Confirmed	[14][94]
2021-01-31 to 2021-04-15	Codecov's Bash Uploader is altered from 31 January, found on 1 April through a checksum mismatch, and could export CI environment variables, credentials, tokens and keys; the actor got the needed credential through an error in Codecov's Docker image creation process; users are told to re-roll all CI credentials	Unnamed	Confirmed	[16]
2021-02-24	CISA AA21-055A: Accellion FTA exploitation (CVE-2021-27101 to CVE-2021-27104) hits government, medical, legal, telecommunications, finance and energy organizations; home study Cl0p and file transfer	Not named on the page used here	Confirmed	[15]
2021-07-02	CISA: supply-chain ransomware attack against multiple MSPs that use Kaseya VSA; CISA urges shutting down VSA servers per Kaseya's guidance; the year's account is in Chronicle 2021	No actor named on the CISA page	Confirmed	[17]
2021-08-12	Wiz researchers report a flaw in the Azure Cosmos DB Jupyter Notebook preview that could let an attacker use another customer's primary read-write key; Microsoft disables the feature, asks a subset of customers to regenerate keys, and finds no customer data accessed beyond the researchers' activity	Researcher report; no attacker	Confirmed	[18]

Date	Event	Actor, as the source names it	Grade	Source
2021-11-03	KEV adds Kaseya VSA CVE-2021-30116, known ransomware use	Not named	Confirmed	[86]

2022 to 2023: identity providers, support vendors and a forged key

Date	Event	Actor, as the source names it	Grade	Source
Late 2021 to 2022	Lapsus$ and related groups, including juveniles, run the activity the CSRB later reviews; SMS and voice MFA defeated by SIM swapping; cloud environments destroyed by mass deletion of VMs, storage and configurations; one victim finds its EDR platform deleted from its cloud environment; the 2022 events are in Chronicle 2022	Lapsus$ and related groups	Confirmed	[33]
2022-01-21	Okta / Sitel: an actor controls a Sitel support engineer's workstation for 25 consecutive minutes and reaches two active customer tenants in the SuperUser application, down from a worst-case estimate of 366; no configuration changes, MFA or password resets were possible; Okta then ends its relationship with Sitel	Unnamed (the CSRB treats it as part of the Lapsus$-class record)	Confirmed	[19][20][33]
2022-03-22	Microsoft describes DEV-0537 (LAPSUS$): bought credentials and session tokens and paid insiders; MFA prompt fatigue, session token replay and SIM swapping; new global admins, an Office 365 mail transport rule routing all mail to an attacker account, VMs created in victims' cloud, cloud resources deleted after exfiltration, code repositories searched for secrets	DEV-0537, G1004 LAPSUS$	Confirmed	[21]
2022-08-25	LastPass: source code and proprietary technical information taken from its development environment	Unnamed	Confirmed	[23]
2022-08 to 2022-10-26	LastPass: information from the first incident is used to target a senior DevOps engineer through vulnerable third-party software, yielding keys to cloud backup storage; a backup of customer vault data is copied (URLs unencrypted; usernames, passwords, notes and form data AES-256 encrypted under keys derived from the master password); disclosed 2022-12-22; master passwords not exfiltrated	Unnamed	Confirmed	[23][24]
2022-09-15	Uber: a contractor's password, likely bought after malware infected a personal device, is used in repeated logins that send two-factor approval requests until one is accepted; the attacker reaches G-Suite, Slack, the HackerOne dashboard and a finance tool; no evidence of access to sensitive user data	Uber "believes" the attacker is affiliated with Lapsus$	Confirmed	[22]
2022-09-24	Microsoft: SOCRadar reports a misconfigured endpoint allowing unauthenticated access to business transaction data with prospective customers; Microsoft calls it a misconfiguration, not a vulnerability, and says SOCRadar "greatly exaggerated the scope"	Exposure, no actor	Confirmed	[25]
2022-12-16 to 2023-01-04	CircleCI: malware missed by antivirus steals an engineer's 2FA-backed SSO session cookie (16 December); reconnaissance 19 December; exfiltration of customer environment variables, tokens and keys, with encryption keys taken from a running process (22 December); a customer reports suspicious GitHub OAuth activity (29 December); disclosure 4 January	Unnamed	Confirmed	[27]
2023-02-08	US Treasury: financial-sector cloud use is concentrated on a small number of providers, so an incident at one could affect many financial clients at once	Policy report	Confirmed	[28]

Date	Event	Actor, as the source names it	Grade	Source
2023-05-15 to 2023-06-16	Storm-0558 uses an acquired Microsoft account (MSA) consumer signing key to forge tokens for Outlook Web Access in Exchange Online and Outlook.com; a customer reports anomalies on 16 June; about 25 organizations, by Microsoft's July count; the year's account is in Chronicle 2023	Storm-0558, which Microsoft calls China-based	Confirmed	[29]
2023-05-27	From 27 May 2023 Cl0p (TA505) exploits MOVEit Transfer CVE-2023-34362 and installs the LEMURLOOT web shell to steal data; separately, CISA estimates TA505 has compromised more than 3,000 US and 8,000 global organizations across its campaigns; home study Cl0p and file transfer	CL0P, TA505	Confirmed	[41]
2023-06-22	Microsoft: Wiz reports that an employee posted a blob URL with an overly permissive SAS token in a public GitHub repository, exposing two former employees' workstation profile backups and internal Teams messages; token revoked 24 June; "No customer data was exposed"; an earlier secret-scanning hit had been marked a false positive	Exposure, no actor	Confirmed	[35]
2023-07-12	CISA and FBI AA23-193A: an FCEB agency found the Storm-0558 activity in mid-June through unexpected AppId values on MailItemsAccessed events, logging that needed G5/E5 licensing; "All mitigation actions for this activity are the responsibility of Microsoft"	Storm-0558	Confirmed	[30]
2023-08-10	CSRB publishes its review of Lapsus$ and related groups; nearly 40 organizations engaged and about 130 public sources	Government review	Confirmed	[33]
2023-09-06	Microsoft's key-acquisition post names an April 2021 crash dump and a compromised engineer account as the most probable path; mail developers had assumed the shared libraries did full validation, so enterprise mail accepted consumer-signed tokens	Storm-0558	Confirmed	[34]
2023-09-28 to 2023-10-17	Okta support-case system: access through a service account whose credentials were saved in an employee's personal Google profile in Chrome on an Okta-managed laptop; files of 134 customers accessed, some HAR files carrying session tokens; 5 customers' sessions hijacked	Unnamed	Confirmed	[36][37]
2023-10-20	Okta discloses that a threat actor with a stolen credential viewed files customers had uploaded to support cases, and revokes embedded session tokens; production service not impacted	Unnamed	Confirmed	[36]
2023-10-30	SEC charges SolarWinds and its CISO with fraud and internal control failures tied to SUNBURST disclosures; allegations unproven at release; home study SolarWinds SUNBURST	Regulator	Confirmed	[38]
2023-11-16	CISA AA23-320A on Scattered Spider lists help-desk impersonation, SIM swap, MFA fatigue, own MFA tokens, a federated identity provider added, EC2 instances used and created, and Snowflake exfiltration, each by ATT&CK id	Scattered Spider	Confirmed	[40]

2024: the year of the customer tenant

Date	Event	Actor, as the source names it	Grade	Source
Late 2023-11 to 2024-01-12	Microsoft: a password spray compromises a legacy non-production test tenant account with no MFA; the actor takes over a legacy test OAuth application with elevated access, creates malicious OAuth apps, grants the Exchange Online full_access_as_app role and reads a very small share of corporate mail, including senior leadership, cybersecurity and legal; detected 12 January, disclosed 19 January; the year's account is in Chronicle 2024 and the actor's record in Threat Actors: Russia	Midnight Blizzard (an alias of G0016 APT29 in the library's data), a Russian state actor	Confirmed	[42][43]
2024-02-08	Okta closes its support-system investigation: Stroz Friedberg's independent review finds no further malicious activity	Unnamed	Confirmed	[44]
2024-02-22	KEV adds ConnectWise ScreenConnect CVE-2024-1709, known ransomware use	Not named	Confirmed	[86]
2024-02-26	CISA AA24-057A: SVR cloud access through password spraying of service accounts, dormant accounts of former staff, stolen tokens, MFA bombing, residential proxies and the actor's own registered devices	SVR	Confirmed	[45]
2024-03-08	Microsoft: Midnight Blizzard used information from exfiltrated email to reach some source code repositories and internal systems, tried secrets customers had shared by email, and raised spray volume up to 10-fold in February; no Microsoft-hosted customer-facing systems found compromised	Midnight Blizzard	Confirmed	[46]
2024-03-12	Microsoft's addendum: no crash dump containing the key was found	Storm-0558	Confirmed	[34]
2024-03-20 (dated); 2024-04-02 (released)	CSRB review of the Summer 2023 Exchange Online intrusion: preventable; "a cascade of security failures at Microsoft"; security culture inadequate; Microsoft does not know how the key was obtained; 25 recommendations	Government review	Confirmed	[47][48][49]
2024-04-02	CISA Emergency Directive 24-02: Midnight Blizzard exfiltrated correspondence between agencies and Microsoft that included authentication details; credential resets required by 30 April 2024; sunset 8 January 2026	Midnight Blizzard	Confirmed	[50]
2024-04-14 to 2024-04-25	AT&T: threat actors access an AT&T workspace on a third-party cloud platform and exfiltrate records of calls and texts of nearly all wireless customers for 1 May to 31 October 2022 and for 2 January 2023; DOJ approves disclosure delays on 9 May and 5 June; at least one person apprehended; 8-K filed 12 July 2024; the filing does not name Snowflake	Unnamed threat actors	Confirmed	[55]
2024-05-20	Live Nation identifies unauthorized activity in a third-party cloud database environment holding mainly Ticketmaster data; a criminal actor offers alleged user data for sale on 27 May; the 8-K does not name Snowflake	Unnamed	Confirmed	[56]

Date	Event	Actor, as the source names it	Grade	Source
2024-05-22 to 2024-06-10	Mandiant: UNC5537 uses infostealer-harvested customer credentials against Snowflake customer instances lacking MFA, credential rotation and network allow lists; about 165 organizations notified from 22 May; not a breach of Snowflake's enterprise environment; CISA relays Snowflake's notice on 3 June	UNC5537, financially motivated	Confirmed	[53][54]
2024-06	Linking the AT&T and Ticketmaster incidents to the Snowflake campaign rests on reporting this study did not open; neither 8-K names Snowflake and Mandiant's post names no victims	Not established in the primary record	Inferred	[53][55][56]
2024-07-19	CrowdStrike releases a Windows sensor configuration update at 04:09 UTC and remediates it at 05:27 UTC; about 8.5 million Windows devices affected by Microsoft's estimate; not a cyberattack; CISA sees threat actors using the outage for phishing	Non-attack event	Confirmed	[58][59][60]

2025 to 2026: OAuth apps, multi-tenant applications and agentic tooling

Date	Event	Actor, as the source names it	Grade	Source
2025 (post of 2025-06-04, update of 2025-08-05)	GTIG: UNC6040 uses voice phishing to get employees to authorize a modified Salesforce Data Loader connected app and steals Salesforce data without exploiting a Salesforce vulnerability; UNC6240 extortion claims the ShinyHunters name; a Google corporate Salesforce instance was hit by similar activity in June 2025; the year's account is in Chronicle 2025	UNC6040 and UNC6240 (ATT&CK campaign C0059)	Confirmed	[67][97]
2025-07-14 to 2025-09-17	Entra ID Actor tokens: a researcher reports that undocumented Actor tokens are not subject to Conditional Access and that the legacy Azure AD Graph API failed to validate the originating tenant, allowing authentication as any user in other tenants with no API-level logging; fixed globally 17 July; CVE-2025-55241 published 4 September; neither source reports in-the-wild exploitation	Researcher report; no attacker	Confirmed	[69][70]
2025-08-08 to 2025-08-18	GTIG: UNC6395 uses compromised Salesloft Drift OAuth tokens to export data from many Salesforce instances and search it for secrets such as AWS keys, passwords and Snowflake tokens; tokens revoked 20 August; Drift Email tokens reach a very small number of Google Workspace accounts on 9 August; not a core Salesforce vulnerability	UNC6395	Confirmed	[68]
2025-08-13	KEV adds N-able N-central CVE-2025-8875 and CVE-2025-8876	Not named	Confirmed	[86]
2026-05 onward (post of 2026-09-09)	Microsoft: passkey-themed help-desk impersonation lures lead to adversary-in-the-middle and device-code phishing, attacker-registered MFA methods, Graph reconnaissance and bulk SharePoint and OneDrive download	Several actors, including Storm-3121 and Storm-3032	Confirmed	[74]
2026-08-03 to 2026-09-11	KEV adds N-able N-central CVE-2026-18577, CVE-2026-18556 and CVE-2026-86218, and ScreenConnect CVE-2026-84869	Not named	Confirmed	[86]
2026-09-04 to 2026-09-19	Cloudflare: a cross-tenant residual-disk-data exposure in Containers and Sandboxes, reported through its bug bounty on 4 September, fixed the same day, rolled out by 7 September, snapshots cleaned by 19 September; no evidence of malicious exploitation	Bug bounty report; no attacker	Confirmed	[75]
2026-09 (post of 2026-09-25)	Microsoft: two compromised service principals in one Azure tenant used to enumerate resources, attempt over 100 storage-account deletions, delete a Key Vault and a Function App, and target backup locks; Microsoft lists T1190, T1078.004, T1526, T1485 and T1490 and does not itself confirm that AI agents ran the activity	Storm-3168	Confirmed	[76]
2026-10-06	Infosecurity Magazine: ASOS customers receive push notifications claiming a Snowflake compromise; ASOS describes unauthorized activity on third-party customer-communication platforms; Snowflake says it found no compromise of its platform	Unnamed	Reported	[85]
2026-10-10 to 2026-10-14	Microsoft: a Storm-0940 password spray targets 327 accounts across eight organizations, over 151,000 failed logons, no observed success	Storm-0940	Confirmed	[77]

Date	Event	Actor, as the source names it	Grade	Source
2026-10-14 to 2026-10-26	Wiz: an actor uses IAM credentials from an AWS account associated with Qubole to assume integration roles customers had created to trust Qubole, reads Lambda variables, Secrets Manager and SSM secrets, validates harvested AWS, Entra and Okta credentials, and downloads S3 data; an AWS spokesperson is reported as saying AWS services were not compromised and operated as designed, and Sentra as confirming dozens of victims	Unnamed	Confirmed (Wiz); Reported (AWS statement, Sentra victim count)	[80][84]
2026-10-15 to 2026-10-21	Microsoft assesses that the ConnectWise compromise was the work of China-state aligned Storm-0940: control of several ConnectWise multi-tenant app identities, sign-ins to customer tenants as those apps, and the ARTEX agentic framework used to attempt sign-ins to more than 2,250 tenants; hundreds of organizations targeted across defense, energy, financial services, government and other sectors; the month's wider record is in PHP2Shell and the October 2026 Attack Wave	Storm-0940	Confirmed	[77]
2026-10-16 to 2026-11-04	ConnectWise: advisory first published 16 October; unauthorized access to application credentials associated with Cloud Backup; backup archives reported encrypted and isolated with no indication of compromise; phased restoration from 28 October requires partners to reset passwords and re-authorize every Microsoft 365 tenant; still ongoing 4 November	Not named by ConnectWise	Confirmed	[78]
2026-10-21	CyberScoop quotes Microsoft's figure of 2,250 tenants at 2,900 sign-in attempts per minute	Storm-0940	Reported	[79]
2026-10-23 to 2026-11-09	Fireworks AI: a third-party cloud provider hosting its R&D machines has an incident on 23 October that the attacker uses on 24 October to reach development machines; billing data, resource metadata and some incomplete model weights and datasets accessed	A financially motivated LLMjacking group, per Fireworks	Confirmed	[81]
2026-11-01 to 2026-11-06	Todyl: one operator signs in to MSP and customer Microsoft 365 and Azure tenants as the victims' own apps with stolen, still-valid secrets; about 45 app registrations at about 18 organizations targeted, 33 or more authenticated, 27 organizations reached, with Partner Center and GDAP used to reach customer tenants; no Microsoft vulnerability; not tied to ConnectWise	Unnamed operator	Confirmed	[82]
2026-11-08 to 2026-11-09	BleepingComputer: N-able takes hosted N-central offline in three regions and tells on-premises customers to shut down servers after a researcher publishes more than 30 alleged zero-days with proof-of-concept code without coordinated disclosure; N-able reports no evidence of exploitation; home study Able2Shell and the RMM Attack Surface	Not applicable	Reported	[83]

Discrepancies in the record

- **How many Storm-0558 victims?** Microsoft's July 2023 post says about 25 organizations; the CSRB says 22 organizations and over 500 individuals, with 503 related personal accounts (**Confirmed** [29][47]). The figures measure different things at different times; this study uses the CSRB's count for impact and Microsoft's for the July 2023 picture.

- **When was the CSRB report published?** The PDF is dated 20 March 2024; DHS released it on 2 April 2024 (**Confirmed** [47][49]).
- **How was the key obtained?** Microsoft's 2023 post gave a crash-dump hypothesis; its 2024 addendum says no crash dump with the key was found, and its leading hypothesis became key material leaving the signing environment through operational errors with access through a compromised engineering account (**Confirmed** [34]). The CSRB says Microsoft does not know (**Confirmed** [47]).
- **What did Capital One's attacker exploit?** Capital One's page says "configuration vulnerability" and names neither SSRF nor a WAF (**Confirmed** [8]). The widely told SSRF-to-metadata account is not in any primary opened here: ATT&CK's T1552.005 page says the metadata API was used in at least one high-profile compromise and cites a news article on the Capital One hack, which this study did not open (**Reported** [10]). The library's Chronicle 2019 records a firewall misconfiguration in the bank's cloud environment (**Inferred** that the two accounts describe the same path [98]).
- **Verizon's exposure size.** UpGuard reported up to 14 million; Verizon's spokesperson said 6 million (**Reported** [4]).
- **Okta 2022 scope.** Okta's first worst-case estimate was 366 tenants; its conclusion was two (**Confirmed** [19]).
- **ConnectWise sequence.** The advisory was first published on 16 October; the disclosure of unauthorized access to application credentials and the phased restoration are dated 28 October in the advisory's updates (**Confirmed** [78]).
- **Agentic labels.** Microsoft names the ARTEX agentic framework for Storm-0940 (**Confirmed** [77]); for Storm-3168, Microsoft's own headline uses the agentic label, but its text ties the activity to an actor another vendor reported as agentic, in reporting this study did not open, and does not itself confirm that AI agents ran the activity (**Confirmed** [76]).

Part 3: the failure modes

Stolen and single-factor credentials

The longest-running failure in the record is a password that works anywhere, used from somewhere it should not be.

- **Dropbox, 2012 and 2016.** The 2012 incident began with passwords reused from other sites, the pattern now called credential stuffing; the set of about 68 million credentials Dropbox confirmed in 2016 was likely obtained in 2012, and passwords unchanged since then were reset four years later (**Confirmed** [1][2]).
- **Snowflake customers, 2024.** UNC5537's credentials came mainly from infostealer malware: VIDAR, RISEPRO, REDLINE, RACOON STEALER, LUMMA and METASTEALER. The earliest infection tied to a used credential dates to November 2020, at least 79.7 percent of the accounts had prior exposure, some credentials had gone unrotated for as long as four years, and the affected instances required no MFA and had no network allow lists (**Confirmed** [53]). In several investigations, Mandiant found the infostealer infection began on contractor systems also used for personal activities (**Confirmed** [53]).
- **Midnight Blizzard against Microsoft, 2023 to 2024.** A low-volume password spray through residential proxies found a legacy test tenant account with no MFA (**Confirmed** [43]). By February 2024 the spray volume had risen as much as 10-fold (**Confirmed** [46]). CISA's AA24-057A describes the same service's

broader cloud tradecraft: password spraying of service accounts and reuse of dormant accounts of former staff (**Confirmed** [45]). The library's Threat Actors: Russia study is the home for the actor.

- **Storm-0940 in October 2026.** A five-day spray against 327 accounts at eight organizations produced over 151,000 failed logons and no observed success (**Confirmed** [77]).

MFA that could be talked past

Having MFA was not the end of the story. Uber's 2022 contractor received repeated two-factor approval requests until one was accepted (**Confirmed** [22]). Microsoft's account of DEV-0537 adds paid insiders who approved MFA prompts, session token replay and SIM swapping (**Confirmed** [21]). The CSRB's Lapsus$ review found SMS and voice MFA insufficient because SIM swapping defeated them, and recommended FIDO2 phishing-resistant passwordless MFA, a federal roadmap for secure authentication, and FCC and FTC oversight of SIM swapping (**Confirmed** [33]). CISA's Scattered Spider advisory lists help-desk impersonation for password and MFA resets and the registration of the actor's own MFA tokens (**Confirmed** [40]). In 2026 Microsoft saw the same move dressed for the passkey era: help-desk impersonation lures themed on passkeys, adversary-in-the-middle and device-code phishing, and attacker-registered MFA methods (**Confirmed** [74]).

Public storage and open endpoints

Exposure is not the same as a breach. Most of the storage stories in the record are exposures someone found and reported:

- UpGuard's 2017 reports of buckets tied to Verizon's vendor NICE Systems, Accenture Cloud Platform, and CENTCOM and PACOM data built by a contractor (**Reported** [4][5][6]).
- Microsoft's 2019 support database, exposed by a network security group change and closed after a researcher's notice; Microsoft found no malicious use (**Confirmed** [13]).
- Microsoft's 2022 endpoint, where Microsoft disputed the finder's scope (**Confirmed** [25]).
- Microsoft's 2023 SAS token, a single over-broad token in a public repository that exposed internal backups and Teams messages but, Microsoft says, no customer data (**Confirmed** [35]).

The provider response that most changed this class came late: from April 2023 every new S3 bucket in every Region has all four Block Public Access settings on and ACLs disabled, and a bucket policy that grants public access is rejected (**Confirmed** [88]).

Instance metadata and server-side request forgery

The Capital One case sits here, and its home is the library's Chronicle 2019. In one paragraph: an outside individual reached Capital One's data on 22 and 23 March 2019 through what the bank calls a "configuration vulnerability", an external researcher reported it on 17 July, and the bank determined the intrusion on 19 July; about 100 million people in the US and 6 million in Canada were affected, including about 140,000 US Social Security numbers, about 80,000 linked bank account numbers and about 1 million Canadian Social Insurance Numbers, and no card numbers or log-in credentials (**Confirmed** [8]). The bank's page gives no further technical detail (**Confirmed** [8]). The widely told account of server-side request forgery against the EC2 instance metadata service is not in any primary opened here: ATT&CK's T1552.005 page cites a news report on the Capital One hack as one high-profile use of the metadata API (**Reported** [10]), and the library's Chronicle 2019 records a firewall misconfiguration and the bank's statement that the flaw was not specific to the cloud. The OCC's $80 million penalty a year later was for the bank's risk assessment before migrating significant IT operations to the public cloud (**Confirmed** [9]).

AWS's response is a matter of record. On 19 November 2019 it introduced IMDSv2: a caller must open a session with an HTTP PUT and present the session token on later requests, tokens are refused to requests carrying an X-Forwarded-For header, and token responses default to a hop limit of 1. AWS named the threats it was aimed at: misconfigured open WAFs, open reverse proxies, unpatched SSRF vulnerabilities, and open layer-3 firewalls or NAT devices (**Confirmed** [11]). IMDSv1 stayed supported (**Confirmed** [11]). On 25 March 2024 AWS added an account-level, per-Region setting that makes IMDSv2 the default for new launches, without changing existing instances, and a CloudWatch metric that counts rejected token-less calls (**Confirmed** [12]). The live ATT&CK page for T1552.005 names SSRF in a public-facing web proxy as an access path and lists TeamTNT, Peirates and TruffleHog among its procedure examples (**Confirmed** [10]).

Secrets in code, CI pipelines and mail

- **Uber, 2016.** An access key posted on a code-sharing website opened third-party cloud storage (**Confirmed** [3]). The FTC release names neither GitHub nor S3 (**Confirmed** [3]).
- **Drizly, 2018 and 2020.** The FTC alleges that cloud login information posted on GitHub was used for cryptomining, and that a later breach ran through the corporate GitHub login (**Confirmed** [26] for the allegations).
- **Codecov, 2021.** An altered uploader could export CI environment variables, credentials, tokens and keys from the CI environments that ran it (**Confirmed** [16]). The npm supply chain study follows the same CI-secret pattern in package worms.
- **CircleCI, 2022.** The stolen session reached production access tokens, and the actor took customer secrets and the keys to decrypt them (**Confirmed** [27]).
- **LAPSUS$, 2022.** The group searched code repositories for exposed secrets (**Confirmed** [21]).
- **Midnight Blizzard, 2024.** Microsoft's own mailboxes held secrets customers had shared by email, and the actor tried to use them (**Confirmed** [46]); CISA's ED 24-02 required agencies to reset authentication details exposed in their correspondence with Microsoft (**Confirmed** [50]).
- **Salesloft Drift, 2025.** UNC6395 searched the Salesforce data it exported for AWS keys, passwords and Snowflake tokens (**Confirmed** [68]).

The Hugging Face supply chain study records the same exposure class on a model hub.

Support systems and the session tokens inside them

Two Okta incidents show how a provider's support channel becomes a path into its customers. In January 2022 an actor controlled a support contractor's workstation for 25 minutes and reached two customer tenants (**Confirmed** [19]); the CSRB later described the pattern as a three-stage supply-chain attack, from a BPO contractor's computer to a service provider's privileged internal tools to that provider's downstream customers (**Confirmed** [33]). In 2023 the support-case system itself was entered through a service account whose credentials had been saved in an employee's personal Google profile on a managed laptop, and session tokens in customer-uploaded HAR files let the actor hijack five customers' sessions (**Confirmed** [37]). Customers, 1Password and BeyondTrust among them, raised the alarm before Okta did, and a logging gap delayed detection: downloads from one tab produced a different log event from ordinary file views (**Confirmed** [37]). Okta's fixes included blocking personal Google profiles on managed Chrome and binding admin session tokens to network location; its closure post adds Zero Standing Privileges for admins, MFA for protected admin actions, IP binding for sessions, anonymizer blocking and allowlisted API network zones (**Confirmed** [37][44]).

Provider control-plane failures

These are the incidents no customer setting could have prevented.

- **Storm-0558, 2023.** A consumer MSA signing key created in 2016, meant to be retired in March 2021, was used to forge tokens, and a validation flaw let enterprise Exchange Online accept them (**Confirmed** [47]). Microsoft says its mail systems adopted the common key metadata endpoint in 2022 without issuer and scope checks, because developers assumed the shared libraries did full validation, and that it now automates key-scope validation (**Confirmed** [34]). The CSRB found that Microsoft paused manual rotation of consumer signing keys in 2021 and did not remove the 2016 key, and it set out what other providers do: automated rotation, keys in HSMs, stateful token validation, narrowly scoped keys, and session-bound rather than bearer tokens (**Confirmed** [47]). It also cited Microsoft's failure, in 2021, to detect the compromise of a laptop belonging to an employee of a recently acquired company before it joined the corporate network (**Confirmed** [47]).
- **Azure Cosmos DB notebooks, 2021.** A preview feature could expose another customer's primary key (**Confirmed** [18]).
- **Entra ID Actor tokens, 2025.** NVD records CVE-2025-55241 as an Azure Entra ID elevation of privilege flaw with CWE-287 (**Confirmed** [69]); the researcher's disclosure explains that the legacy Azure AD Graph API did not validate the originating tenant of an Actor token, and that such tokens bypassed Conditional Access with no API-level logging (**Confirmed** [70]).
- **Cloudflare Containers, 2026.** Residual disk data could cross tenants until the 4 September fix (**Confirmed** [75]).

Third-party SaaS integrations and OAuth tokens

The Salesforce cases of 2025 show two routes to the same data. UNC6040 talked employees into authorizing a modified connected app by phone (**Confirmed** [67]); UNC6395 simply used OAuth tokens already granted to a trusted integration, Salesloft Drift, and exported data from many Salesforce instances (**Confirmed** [68]). In neither case did the source find a Salesforce vulnerability (**Confirmed** [67][68]). ATT&CK records the vishing campaign as C0059 Salesforce Data Exfiltration, and the library's ATT&CK data files UNC6240 as an alias of G1057 ShinyHunters (**Confirmed** [97]). This study does not tie ShinyHunters to UNC6395 or to UNC5537, because no opened record does (**Confirmed** [68][53]).

Delegated trust: MSPs, multi-tenant apps and cross-account roles

CISA's TA17-117A in 2017 described IT service providers being targeted so their credentials and shared infrastructure could reach customer environments (**Confirmed** [7]). Kaseya VSA in 2021 turned an MSP tool into a ransomware delivery channel; the library's Chronicle 2021 and The Ransomware Ecosystem cover it (**Confirmed** [17]). The KEV catalog now carries a run of MSP-tool flaws: Kaseya VSA, ScreenConnect in 2024 and 2026, and five N-able N-central flaws from August 2025 to September 2026 (**Confirmed** [86]). The Able2Shell study follows that run to the November 2026 disclosure.

October and November 2026 brought the cloud-native form of the same pattern, three times in a month:

- **ConnectWise Cloud Backup.** Storm-0940 took control of several ConnectWise multi-tenant application identities and authenticated into customer tenants as those apps (**Confirmed** [77]). Microsoft lists T1595, T1078.004, T1195, T1199, T1098.003, T1098.001, T1528, T1555.006, T1087.004 and T1580 (**Confirmed** [77]). ConnectWise required partners to re-authorize every Microsoft 365 tenant (**Confirmed** [78]).
- **Qubole.** Integration roles that customers had created to trust Qubole's AWS account were assumed by an actor holding that account's IAM credentials (**Confirmed** [80]).
- **App secrets at MSPs.** Todyl saw one operator sign in as victims' own Entra applications with still-valid secrets and use Partner Center and GDAP to reach customer tenants (**Confirmed** [82]).

Todyl found no Microsoft vulnerability in its cases, Microsoft describes the ConnectWise intrusion as abuse of ConnectWise's own application identities, and AWS is reported as saying its services operated as designed in the Qubole campaign (**Confirmed** [82][77]; **Reported** [84]).

Destruction in the cloud

Data theft dominates the record, but destruction is there too. The CSRB's Lapsus$ review records mass deletion of VMs, storage and configurations, and a victim whose EDR platform was deleted from its cloud environment (**Confirmed** [33]). Microsoft's DEV-0537 report describes deletion of cloud resources after exfiltration (**Confirmed** [21]). In September 2026 Storm-3168 used two compromised service principals to attempt over 100 storage-account deletions, delete a Key Vault and a Function App, and go after backup locks (**Confirmed** [76]).

Part 4: the government and regulator record

The two CSRB reviews

The Cyber Safety Review Board has twice examined cloud identity at length.

Lapsus$ and related groups (10 August 2023). Activity ran from late 2021 into 2022; the perpetrators included juveniles; the Board engaged nearly 40 organizations and about 130 public sources (**Confirmed** [33]). Its findings: SMS and voice MFA were defeated by SIM swapping; initial access brokers and infostealer markets were effective ways in; organizations often left BPOs and other third parties out of their risk programs; and attackers destroyed cloud environments (**Confirmed** [33]).

The Summer 2023 Exchange Online intrusion (dated 20 March 2024; released 2 April 2024). The Board found the intrusion preventable, Microsoft's security culture inadequate and in need of an overhaul, and listed seven grounds, among them a cascade of avoidable errors (**Confirmed** [47]). It recorded that the actor downloaded about 60,000 emails from State Department accounts over at least six weeks of access (**Confirmed** [47]), that State detected the intrusion through a custom alert on a log it could see only because it had bought the G5 licence (**Confirmed** [47]), and that Commerce and the UK victims, without premium logging, could not look back at past activity (**Confirmed** [47]). It also noted the separate compromise of Microsoft corporate email that Microsoft disclosed in January 2024 (**Confirmed** [47]). Its 25 recommendations include:

Recommendation	What it asks	Source
4	Offering security logging only as a paid package should stop	[47]
10	A CISA-led default audit logging standard: every access to customer data, including the provider's own, logged and available to the customer at no extra charge, kept at least six months	[47]
16	Providers should promptly correct significant factual inaccuracies	[47]
17	CVEs for every cloud vulnerability, including those that need no customer action	[47]
21 to 24	FedRAMP changes, including special reviews and stronger AU-2 audit logging	[47]

DHS released the report on 2 April 2024 and urged cloud providers to build security in by design (**Confirmed** [49]). The Board said industry links Storm-0558 to Operation Aurora and the 2011 RSA SecurID incident (**Reported**, relayed by the CSRB [47]). The FireEye Mandiant intrusion study records the 2011 RSA breach among earlier security-vendor breaches. The library's Threat Actors: China study notes that Storm-0558 has no ATT&CK object.

CISA's directives and baselines

- **AA21-008A (8 January 2021)** explained how to find SolarWinds-era activity in Microsoft tenants, including the MailItemsAccessed event, whose application-ID detail needed G5 or E5 licensing; it named Sparrow (with the Aviary dashboard), Hawk and CrowdStrike CRT, noted 90 days of audit retention on G3/E3, and recommended a SIEM for longer retention (**Confirmed** [14]).
- **AA23-193A (12 July 2023)** recommended Purview Audit (Premium), the Unified Audit Log, and 12 months of active and 18 months of cold retention; CISA and the FBI knew of no other log that would have caught Storm-0558 (**Confirmed** [30]).
- **ED 24-02 (2 April 2024)** ordered credential resets after Midnight Blizzard's theft of agency correspondence, and was sunset on 8 January 2026 (**Confirmed** [50]).
- **SCuBA.** CISA created the Secure Cloud Business Applications project in 2022 with secure configuration baselines for Microsoft 365 and Google Workspace, and released the free ScubaGear and ScubaGoggles

assessment tools in 2023 (**Confirmed** [65]).

- **BOD 25-01 (17 December 2024)** made the baselines mandatory for federal agencies: tenant inventory by 21 February 2025, assessment tools and continuous reporting by 25 April 2025, and the mandatory "shall" policies by 20 June 2025; only the Microsoft 365 baselines were final at issuance (**Confirmed** [64]). Its rationale cites incidents where improper cloud security configuration "introduced substantial risk", without naming them (**Confirmed** [64]).
- **The Expanded Cloud Logs Implementation Playbook** covers the newly available Audit (Standard) logs, such as mail items accessed and sent and searches, and how to ingest them into a SIEM for E3/G3 and higher licences; the page shows a revision of 1 May 2026 (**Confirmed** [73]).

FedRAMP

GSA announced FedRAMP 20x in March 2025, built on Key Security Indicators and automated validation. The Phase 1 low pilot ran April to September 2025 with first authorizations in late July 2025, the Phase 2 moderate pilot authorized its first cohort on 6 March 2026, and FedRAMP estimates it will stop taking new Rev5 certifications on 11 June 2027 (**Confirmed** [66]).

Financial, consumer and securities regulators

Date	Regulator	Action	Grade	Source
2018-04-12	FTC	Expanded Uber settlement over the 2016 breach and its non-disclosure until November 2017	Confirmed	[3]
2020-08-06	OCC	$80 million penalty and cease and desist order against Capital One for cloud migration risk assessment	Confirmed	[9]
2022-10-24	FTC	Proposed order against Drizly covering the 2018 and 2020 incidents; binds the CEO personally	Confirmed	[26]
2023-02-08	US Treasury	Report on financial-sector cloud adoption: concentration, transparency to community banks, human-capital gaps, provider bargaining power	Confirmed	[28]
2023-07-26	SEC	Cyber disclosure rules: Form 8-K Item 1.05 within four business days of a materiality determination, from 18 December 2023	Confirmed	[32]
2023-10-30	SEC	Charges against SolarWinds and its CISO (allegations unproven at release)	Confirmed	[38]
2024-07-12	SEC filing	AT&T's Item 1.05 8-K on the call-records theft, with two DOJ-approved delays	Confirmed	[55]

The AT&T filing shows the new rule working as written: a third-party cloud platform named only in general terms, exact exfiltration dates, and a disclosure delayed twice with DOJ approval (**Confirmed** [55]; the reading is **Inferred**).

Part 5: what the providers changed

Logging

AWS launched CloudTrail on 13 November 2013 as a service that records API calls made on an account and delivers the logs to S3 (**Confirmed** [87]). Microsoft's Purview story is the reverse: the mailbox-access events that AA21-008A recommended for SolarWinds-era hunting, and that caught Storm-0558, sat behind premium licensing until Microsoft announced, on 19 July 2023, that Audit (Standard) customers would get detailed email access logs and more than 30 other log types at no extra cost, with default retention rising from 90 to 180 days and rollout from September 2023, coordinated with CISA (**Confirmed** [31]). This study reads that change as the policy response to a detection gap in which only a premium-logging customer could see Storm-0558, a reading the CSRB's later Recommendation 4 supports (**Inferred** [47]).

Keys, MFA and disclosure: the Secure Future Initiative

Date	Change	Grade	Source
2023-11-02	Microsoft launches the Secure Future Initiative: AI-based defense, software engineering advances and international norms, including automated key management on HSMs and confidential computing and a goal of mitigating cloud vulnerabilities 50 percent faster	Confirmed	[39]
2024-05-03	Microsoft's CEO tells staff to put security above other priorities; the memo sets out secure by design, by default and in operations, six pillars, and ties part of senior leadership compensation to security progress	Confirmed	[51]
2024-05-03	Microsoft's SFI expansion cites the CSRB findings and commits to HSM-protected keys with automatic rotation, phishing-resistant MFA on all user accounts, security logs kept at least two years with six months available to customers, and Deputy CISOs	Confirmed	[52]
2024-06-27	Microsoft commits to CVEs for critical cloud service vulnerabilities even when customers need take no action, citing the CNA rules and SFI; the post does not cite the CSRB, though it matches Recommendation 17	Confirmed	[57]
2024-08-15	Mandatory MFA for Azure sign-ins: the Azure portal and the Entra and Intune admin centers from October 2024; CLI, PowerShell, the mobile app and IaC tools from early 2025	Confirmed	[63]
2025-11 and 2026-07	The SFI Trust Center lists progress reports for November 2025 and July 2026; the page itself gives no metrics	Confirmed	[72]

Microsoft's mandatory-MFA post says, citing its own research, that MFA can block more than 99.2 percent of account compromise attacks; that is a vendor statistic this study did not test (**Reported** [63]).

Defaults at AWS and Snowflake

Date	Change	Grade	Source
2019-11-19	IMDSv2 introduced, opt-in per instance	Confirmed	[11]
2022-12-13 announced; 2023-04-27 complete	New S3 buckets have all four Block Public Access settings on and ACLs disabled; public-granting bucket policies are rejected	Confirmed	[88]
2024-03-25	IMDSv2 can be set as the account default for new launches in each Region	Confirmed	[12]
2025-09 to 2026-01 (estimated)	Snowflake requires MFA for Snowsight password sign-ins	Confirmed	[71]
2026-05 to 2026-07 (estimated)	New Snowflake human users need MFA; new non-human users must be SERVICE type	Confirmed	[71]
2026-08 to 2026-10 (estimated)	Password-only sign-in blocked for all Snowflake human users; legacy service users moved off passwords	Confirmed	[71]

The gap between incident and default is measurable in the record: more than four years from IMDSv2's launch to an account-level default, and more than a year from the Snowflake campaign to the first enforcement phase (**Inferred** from [11][12][53][71]).

Guardrails and findings at AWS

AWS Organizations service control policies set the maximum permissions available in member accounts; they never grant permissions and do not apply to the management account (**Confirmed** [92]). GuardDuty raises findings when EC2 instance-role credentials are used from an external IP address or from another AWS account, both at default severity High, and when a CloudTrail trail is disabled or deleted (**Confirmed** [93]).

Part 6: sectors and systemic risk

- **Finance.** Capital One's breach and penalty, and Treasury's 2023 warning that cloud concentration means one provider incident can affect many financial clients at once (**Confirmed** [8][9][28]).
- **Government.** Storm-0558 reached the State and Commerce departments and the House of Representatives (**Confirmed** [47]); Accellion victims included federal and SLTT government (**Confirmed** [15]); Storm-0940 targeted government among other sectors (**Confirmed** [77]).
- **Telecommunications.** AT&T's call records, Verizon's vendor bucket, Accellion's telecommunications victims, and TA17-117A's Communications sector (**Confirmed** [55][15][7]; **Reported** for Verizon [4]).
- **Healthcare through vendors.** TA17-117A named Healthcare and Public Health among initial victims (**Confirmed** [7]). The clearinghouse case is the home study Change Healthcare 2024, and the vendor-breach pattern is followed in the Healthcare Threat Watchlist.
- **MSP downstream clients.** Kaseya VSA reached the customers of MSPs that used it; Storm-0940 targeted organizations in defense, energy, financial services and government; and Todyl's cases reached MSP downstream clients in government, energy, education, legal and nonprofit sectors (**Confirmed** [17][77][82]).

- **AI platforms.** Fireworks AI says billing data, resource metadata and some incomplete model weights and datasets were accessed after a security incident at a third-party cloud provider hosting its R&D machines, in activity it links to an LLMjacking group (**Confirmed** [81]). The library's AI threats study is the home for AI-specific threats.

The non-attack contrast: CrowdStrike, July 2024

The largest availability event in this record was not an attack. CrowdStrike released a Windows sensor configuration update at 04:09 UTC on 19 July 2024 and remediated it at 05:27 UTC; Falcon for Windows 7.11 and later hosts online in that window could be affected, and Linux and macOS were not (**Confirmed** [58]). CrowdStrike states the outage was not the result of or related to a cyberattack (**Confirmed** [58]). Its root-cause analysis found that an interprocess-communication template type defined 21 inputs while the integration code supplied 20, so a content file with a non-wildcard 21st criterion caused an out-of-bounds read and a crash; mitigations include runtime bounds checks, staged deployment and two independent third-party code reviews, and about 99 percent of Windows sensors were back online by 29 July (**Confirmed** [62]). Its preliminary review called Rapid Response Content configuration data rather than code and committed to canary-first deployment and customer control over when content updates land (**Confirmed** [61]). Microsoft estimated 8.5 million Windows devices affected, less than one percent of all Windows machines (**Confirmed** [59]). CISA confirmed the cause was not malicious, and observed threat actors using the outage for phishing, including a malicious ZIP aimed at CrowdStrike customers in Latin America (**Confirmed** [60]). The lesson for cloud risk is concentration: a trusted vendor's update channel produced a cross-sector outage that attackers then exploited (**Inferred** [60]).

Part 7: the defender view

What the record recommends

Control	Where the record credits it	Grade	Source
Phishing-resistant MFA on every human and admin path	CSRB Lapsus$ recommendation; Microsoft mandatory Azure MFA (not necessarily phishing-resistant); Snowflake retiring passwords; Okta MFA for protected admin actions	Confirmed	[33][63][71][44]
Short-lived and OIDC credentials	CircleCI's instruction to every customer	Confirmed	[27]
IMDSv2	AWS's response to SSRF and open proxies, now an account default for new launches	Confirmed	[11][12]
Credential rotation and revocation	Codecov re-roll; CircleCI rotation; Salesloft Drift token revocation; ED 24-02 resets	Confirmed	[16][27][68][50]
Session binding	Okta admin sessions bound to network location; CSRB's call for session-bound tokens	Confirmed	[37][47]
Network allow lists	Missing on every affected Snowflake instance	Confirmed	[53]
Canary service accounts and short session lifetimes	AA24-057A mitigations	Confirmed	[45]
App and consent governance	Microsoft's Midnight Blizzard guidance: audit app-only privileges and ApplicationImpersonation, App governance, Conditional Access app control	Confirmed	[43]
Organization guardrails	AWS service control policies	Confirmed	[92]
Mandatory secure baselines	SCuBA and BOD 25-01	Confirmed	[65][64]

Detection that worked, and why it was rare

State Department's catch of Storm-0558 is the clearest detection story in the record, and the CSRB explains why it was rare. State's SOC saw anomalies on 15 June 2023, and on 16 June a custom rule its staff called "Big Yellow Taxi", built over the MailItemsAccessed log, alerted; State contacted Microsoft the same day (**Confirmed** [47]). The rule was the product of three years of work enumerating every application that touched mailboxes and alerting on deviations from that baseline; the Board heard that few organizations analyzed MailItemsAccessed, and that buying the logging alone "would not have been enough" (**Confirmed** [47]).

The equivalent on AWS is CloudTrail with GuardDuty's findings for instance-credential use outside the instance and for disabled trails (**Confirmed** [87][93]). In both clouds, the decisive evidence was an access log someone had turned on, kept and baselined (**Inferred** from [47][30][14][93]).

Customers also caught providers. A customer reported Storm-0558 to Microsoft (**Confirmed** [29]); 1Password and BeyondTrust raised the Okta 2023 alarm (**Confirmed** [37]); a customer reported suspicious GitHub OAuth activity at CircleCI (**Confirmed** [27]); and a checksum mismatch, not an intrusion alert, exposed the Codecov alteration (**Confirmed** [16]). Your own logs are the provider's early warning as well as your own (**Inferred**).

Responding in a shared environment

- **Assume the secret is gone, and rotate everything it could reach.** Codecov and CircleCI told every customer to rotate all CI secrets, and the Drift tokens were revoked (**Confirmed** [16][27][68]).
- **Hunt in the data the actor took for the secrets inside it.** UNC6395 and Midnight Blizzard both mined stolen data for further credentials (**Confirmed** [68][46]).
- **Prefer behavior over IP indicators.** Midnight Blizzard's residential proxies made IP-based indicators infeasible; AA24-057A favors signals such as unexpected user-agent changes (**Confirmed** [43][45]).
- **Know your delegated trust.** In the 2026 MSP cases, recovery meant re-authorizing every tenant or removing still-valid app secrets (**Confirmed** [78][82]).
- **Use the library's guide.** Investigate a Cloud Compromise walks the evidence sources step by step.

What is overstated and what is understated

- **Overstated: "the cloud provider was hacked."** For Snowflake 2024, Mandiant found no evidence of a breach of Snowflake's enterprise environment; for Salesloft Drift, GTIG says the theft did not stem from a core Salesforce vulnerability; for Capital One the regulator cited the bank's own risk assessment; for Qubole, AWS is reported as saying its services operated as designed; for ASOS in 2026, Snowflake is reported as finding no compromise of its platform (**Confirmed** [53][68][9]; **Reported** [84][85]). Headlines that name the platform describe the blast radius, not the root cause (**Inferred**).
- **Overstated: exposure as breach.** Microsoft found no malicious use of its 2019 database, disputed the finder's scope in 2022, and found no customer data in the 2023 SAS token exposure; researcher-found cross-tenant flaws in 2021, 2025 and 2026 carry no record of exploitation (**Confirmed** [13][25][35][18][70][75]).
- **Overstated: single-cause stories.** Microsoft's crash-dump account was corrected, and the Capital One SSRF chain is told mostly through secondary reporting (**Confirmed** [34][47]; **Reported** [10]).
- **Overstated: "agentic" attacks as a settled fact.** Microsoft names an agentic framework for Storm-0940, but does not itself confirm AI agents ran Storm-3168's activity (**Confirmed** [77][76]).
- **Understated: provider-side control-plane risk.** Storm-0558, the Cosmos DB notebook flaw and the Entra ID Actor token flaw sat entirely in the provider's band, and until June 2024 Microsoft had not committed to CVEs for critical cloud flaws that need no customer action; the CSRB said providers' failure to register such CVEs ran counter to accepted norms (**Confirmed** [47][18][70][57]).
- **Understated: logging as a paid tier.** Detection of the worst intrusion in the record depended on a premium licence until September 2023 (**Confirmed** [47][31]).
- **Understated: the delegated-trust layer.** OAuth apps, cross-account roles, MSP multi-tenant apps and GDAP let one stolen secret reach hundreds or thousands of tenants (**Inferred** from [77][80][82][68]).
- **Understated: the age of the secrets.** Four-year-old Snowflake passwords, a 2012 Dropbox credential set reset in 2016, and a key left on a code-sharing site (**Confirmed** [53][2][3]).
- **Understated: the provider's defaults.** The shared-responsibility model puts configuration on the customer, but S3 public-block, IMDSv2 and Snowflake MFA all became defaults one to several years after the incidents that showed the need (**Confirmed** [88][12][71]; **Inferred** for the reading).

Part 8: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND. Every id was checked against the live ATT&CK page or the library's data files on 11 November 2026, and every technique and object linked below has a generated page in the library (**Confirmed** [97]). Cloud incidents in this record touch no industrial control systems, so there is no ATT&CK for ICS table. The Scattered Spider advisory lists one ATT&CK for Mobile technique, T1451 SIM Card Swap; the library carries it in its mobile data but has no generated mobile page, so it is named here and not linked (**Confirmed** [40][97]).

Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment. T1562.008 Disable or Modify Cloud Logs is revoked in v20.0 and maps through `data/attack/superseded_by.jsonl` to T1685.002 Disable or Modify Cloud Log (**Confirmed** [97]). "Listed" in the Basis column means the source names the id itself; "Mapped" means the source describes the behavior and the id is this study's reading (**Inferred**).

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the dated record	Basis	Source
T1595	Active Scanning	Reconnaissance	Storm-0940, ConnectWise, Oct 2026	Listed	[77]
T1598.004	Spearphishing Voice	Reconnaissance	ATT&CK's C0059 description of UNC6040's vishing, 2024 to 2025	Listed (ATT&CK)	[97][67]
T1190	Exploit Public-Facing Application	Initial Access	Storm-3168, Sep 2026; Capital One, Mar 2019 (on the Reported SSRF basis)	Listed (Storm-3168); Mapped (Capital One)	[76][8][10]
T1195	Supply Chain Compromise	Initial Access	Storm-0940, ConnectWise, Oct 2026	Listed	[77]
T1195.002	Compromise Software Supply Chain	Initial Access	Codecov Bash Uploader, Jan to Apr 2021	Mapped	[16]
T1199	Trusted Relationship	Initial Access	AA23-320A, Nov 2023; Okta support system, Sep to Oct 2023; Salesloft Drift, Aug 2025; Storm-0940, Oct 2026; Qubole roles and MSP app secrets, Oct to Nov 2026	Listed (AA23-320A, Storm-0940); Mapped (others)	[40][37][68][77][80][82]
T1566.004	Spearphishing Voice	Initial Access	AA23-320A help-desk impersonation, Nov 2023; UNC6040 vishing, 2025	Listed (AA23-320A); Mapped (UNC6040)	[40][67]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-320A, Nov 2023	Listed	[40]
T1078.002	Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-320A, Nov 2023	Listed	[40]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Uber, 2016; Capital One, 2019; Okta, 2023; Midnight Blizzard, 2023 to 2024; UNC5537, 2024; Storm-3168, Sep 2026; Storm-0940, Oct 2026	Listed (Storm-3168, Storm-0940); Mapped (others)	[3][8][37][42][53][76][77]
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	AA21-008A credentials added to service principals, Jan 2021; ATT&CK procedures for C0024 and C0027; Storm-0940, Oct 2026	Listed (ATT&CK, Storm-0940); Mapped (AA21-008A)	[14][94][77]

Id	Name	Tactic (v20.0)	Where it appears in the dated record	Basis	Source
T1098.003	Additional Cloud Roles	Persistence, Privilege Escalation	DEV-0537 new global admins, Mar 2022; Midnight Blizzard full_access_as_app grant, Jan 2024; Storm-0940, Oct 2026	Listed (Storm-0940); Mapped (others)	[21][43][77]
T1098.005	Device Registration	Persistence, Privilege Escalation	AA24-057A, the SVR registering its own devices, Feb 2024	Mapped	[45]
T1671	Cloud Application Integration	Persistence	Midnight Blizzard malicious OAuth apps, Jan 2024	Mapped	[43]
T1556.006	Multi-Factor Authentication	Defense Impairment, Persistence, Credential Access	AA23-320A own MFA tokens, Nov 2023; attacker-registered MFA methods, 2026	Listed (AA23-320A); Mapped (2026)	[40][74]
T1484.002	Trust Modification	Defense Impairment, Privilege Escalation	AA23-320A federated identity provider added, Nov 2023	Listed	[40]
T1578.002	Create Cloud Instance	Defense Impairment	DEV-0537 VMs in victims' cloud, Mar 2022; AA23-320A, Nov 2023	Listed (AA23-320A); Mapped (DEV-0537)	[21][40]
T1685.002	Disable or Modify Cloud Log	Defense Impairment	Detection context only: GuardDuty's finding for disabled trails; no incident here documents it	Mapped (detection context)	[93][97]
T1070	Indicator Removal	Stealth	Salesloft Drift query-job deletion, Aug 2025	Mapped	[68]
T1110.003	Password Spraying	Credential Access	Midnight Blizzard, Nov 2023 to Feb 2024; AA24-057A, Feb 2024; Storm-0940 spray, Oct 2026	Mapped	[42][46][45][77]
T1110.004	Credential Stuffing	Credential Access	Dropbox, Jul 2012	Mapped	[1][2]
T1621	Multi-Factor Authentication Request Generation	Credential Access	DEV-0537, Mar 2022; Uber, Sep 2022; AA23-320A, Nov 2023; AA24-057A, Feb 2024	Listed (AA23-320A); Mapped (others)	[21][22][40][45]

Id	Name	Tactic (v20.0)	Where it appears in the dated record	Basis	Source
T1606	Forge Web Credentials	Credential Access	Storm-0558 forged tokens, May to Jun 2023; AA23-320A, Nov 2023	Listed (AA23-320A); Mapped (Storm-0558; parent only, because the forged items are tokens, not SAML or cookies)	[29][34][40]
T1606.002	SAML Tokens	Credential Access	AA21-008A forged SAML tokens after the SolarWinds compromise, Jan 2021	Mapped	[14]
T1528	Steal Application Access Token	Credential Access	CircleCI OAuth tokens, Dec 2022; AA24-057A token theft, Feb 2024; Salesloft Drift, Aug 2025; Storm-0940, Oct 2026	Listed (Storm-0940); Mapped (others)	[27][45][68][77]
T1539	Steal Web Session Cookie	Credential Access	CircleCI SSO cookie, Dec 2022; Okta HAR session tokens, Sep to Oct 2023	Mapped	[27][37]
T1552	Unsecured Credentials	Credential Access	Codecov, 2021; CircleCI, 2022; Midnight Blizzard secrets in mail, Mar 2024; Salesloft Drift secrets in exported data, Aug 2025	Mapped	[16][27][46][68]
T1552.001	Credentials In Files	Credential Access	Uber key on a code-sharing site, 2016; Codecov, 2021; DEV-0537 repository secrets, Mar 2022	Mapped	[3][16][21]
T1552.005	Cloud Instance Metadata API	Credential Access	Capital One, Mar 2019 (Reported basis); the threat IMDSv2 addresses, Nov 2019; GuardDuty instance-credential findings	Mapped	[10][11][93]
T1555.003	Credentials from Web Browsers	Credential Access	Okta service-account credential saved in a personal browser profile, 2023 (Okta calls the exposure route only most likely)	Mapped	[37]
T1555.006	Cloud Secrets Management Stores	Credential Access	Storm-0940, Oct 2026; Qubole Secrets Manager reads, Oct 2026	Listed (Storm-0940); Mapped (Qubole)	[77][80]
T1087.004	Cloud Account	Discovery	Storm-0940, Oct 2026	Listed	[77]
T1526	Cloud Service Discovery	Discovery	Storm-3168, Sep 2026	Listed	[76]

Id	Name	Tactic (v20.0)	Where it appears in the dated record	Basis	Source
T1538	Cloud Service Dashboard	Discovery	AA23-320A, Nov 2023	Listed	[40]
T1580	Cloud Infrastructure Discovery	Discovery	Storm-0940, Oct 2026	Listed	[77]
T1021.007	Cloud Services	Lateral Movement	AA23-320A existing EC2 instances, Nov 2023	Listed	[40]
T1550.001	Application Access Token	Lateral Movement	Storm-0558 forged tokens, 2023; AA24-057A, Feb 2024; Salesloft Drift, Aug 2025; the CVE-2025-55241 Actor token risk, Jul 2025	Mapped	[29][45][68][70]
T1550.004	Web Session Cookie	Lateral Movement	DEV-0537 session token replay, Mar 2022; CircleCI, Dec 2022; Okta session hijacks, Oct 2023	Mapped	[21][27][37]
T1114.002	Remote Email Collection	Collection	Storm-0558, May to Jun 2023; Midnight Blizzard over EWS, Nov 2023 to Jan 2024	Mapped	[29][47][43]
T1114.003	Email Forwarding Rule	Collection	DEV-0537 mail transport rule, Mar 2022	Mapped	[21]
T1213	Data from Information Repositories	Collection	UNC5537 against Snowflake instances, 2024	Mapped	[53]
T1213.003	Code Repositories	Collection	DEV-0537 repository searches, Mar 2022	Mapped	[21]
T1213.004	Customer Relationship Management Software	Collection	UNC6040 Salesforce theft, 2025; Salesloft Drift, Aug 2025	Mapped	[67][68]
T1530	Data from Cloud Storage	Collection	Uber, 2016; Capital One, 2019; AA23-320A, Nov 2023; bulk OneDrive download, 2026; Qubole S3 downloads, Oct 2026	Listed (AA23-320A); Mapped (others)	[3][8][40][74][80]
T1090.002	External Proxy	Command and Control	Midnight Blizzard residential proxies, Jan 2024; AA24-057A, Feb 2024	Mapped	[43][45]
T1567	Exfiltration Over Web Service	Exfiltration	AA23-320A Snowflake exfiltration, Nov 2023; UNC5537, 2024	Listed (AA23-320A); Mapped (UNC5537)	[40][53]

Id	Name	Tactic (v20.0)	Where it appears in the dated record	Basis	Source
T1485	Data Destruction	Impact	DEV-0537 and the CSRB's Lapsus$ record, 2021 to 2022; Storm-3168, Sep 2026	Listed (Storm-3168); Mapped (Lapsus$)	[21][33][76]
T1490	Inhibit System Recovery	Impact	Storm-3168 backup-lock targeting, Sep 2026	Listed	[76]

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to this study	Source
APT29	G0016	The library's data lists Midnight Blizzard, NOBELIUM and UNC2452 as aliases; Microsoft corporate email, 2023 to 2024; AA24-057A SVR cloud tradecraft	[97][42][45]
SolarWinds Compromise	C0024	ATT&CK's T1098.001 procedure: APT29 added credentials to OAuth applications and service principals; home study SolarWinds SUNBURST	[94][14]
LAPSUS$	G1004	DEV-0537 in Microsoft's 2022 report; the CSRB review; Uber's 2022 belief of affiliation	[21][33][22]
Scattered Spider	G1015	Subject of AA23-320A	[40]
C0027	C0027	ATT&CK's T1098.001 procedure: Scattered Spider created temporary federated credentials	[94]
Salesforce Data Exfiltration	C0059	ATT&CK's campaign for UNC6040's vishing and data theft	[97][67]
ShinyHunters	G1057	The library's data lists UNC6240 as an alias, the extortion actor GTIG says claimed the ShinyHunters name in 2025; ATT&CK lists it under T1528. Not bound to UNC6395 or UNC5537	[97][67][95]
TA505	G0092	MOVEit, 2023, per AA23-158A; home study Cl0p and file transfer	[41]
PlugX	S0013	Named (as PlugX/SOGU) in TA17-117A on MSP intrusions	[7]
RedLeaves	S0153	Named in TA17-117A	[7]

Context only, not tied to an incident in this record: ATT&CK lists G0139 TeamTNT, S0683 Peirates and S9009 TruffleHog as T1552.005 procedure examples; S1091 Pacu and G1053 Storm-0501 under T1098.001; and S0677 AADInternals under T1528 (**Confirmed** [10][94][95]). TA17-117A names APT10 only through the reports it cites, so G0045 menuPass, whose library aliases include APT10, is not bound here (**Confirmed** [7][97]).

Storm-0558, UNC5537, UNC6395, Storm-0940, Storm-3168, Storm-3121 and Storm-3032 have no ATT&CK group object in the library's data and are named in text only (**Confirmed** [97]).

CWE and CAPEC

Weakness or pattern	Name	Where it fits	Basis	Source
CWE-287	Improper Authentication	CVE-2025-55241	Assigned by NVD	[69]
CWE-346	Origin Validation Error	Actor tokens accepted without validating the originating tenant	Inferred	[70]
CWE-308	Use of Single-factor Authentication	UNC5537's accounts; Midnight Blizzard's test account	Inferred	[53][43]
CWE-522	Insufficiently Protected Credentials	Okta service account, 2023; CircleCI, 2022; Codecov, 2021	Inferred	[37][27][16]
CWE-798	Use of Hard-coded Credentials	Uber's posted access key, 2016	Inferred	[3]
CWE-306	Missing Authentication for Critical Functionality	Microsoft's 2022 endpoint	Inferred	[25]
CWE-732 and CWE-200	Incorrect Permission Assignment for Critical Resource; Exposure of Sensitive Information to an Unauthorized Actor	Microsoft's 2023 SAS token	Inferred	[35]
CWE-284	Improper Access Control	Cosmos DB notebook, 2021	Inferred	[18]
CWE-918	Server-Side Request Forgery	A threat IMDSv2 was built against; for Capital One, only on the Reported SSRF basis, not as a stated root cause	Inferred	[11][10]
CWE-347	Improper Verification of Cryptographic Signature	Considered for Storm-0558's key-scope flaw; Microsoft assigned no CWE and no CVE record states one, so it is not bound	Not bound	[34]
CAPEC-560	Use of Known Domain Credentials	Snowflake 2024; the library maps it to T1078	Inferred	[53][97]
CAPEC-565	Password Spraying	Midnight Blizzard; maps to T1110.003	Inferred	[42][97]
CAPEC-600	Credential Stuffing	Dropbox 2012; maps to T1110.004	Inferred	[1][97]
CAPEC-196	Session Credential Falsification through Forging	Storm-0558; maps to T1606	Inferred	[34][97]
CAPEC-593	Session Hijacking	Okta 2023; Salesloft Drift; maps to T1550.001	Inferred	[37][68][97]
CAPEC-60	Reusing Session IDs (aka Session Replay)	CircleCI; maps to T1550.004	Inferred	[27][97]
CAPEC-21	Exploitation of Trusted Identifiers	Salesloft Drift; maps to T1528 and T1539	Inferred	[68][97]
CAPEC-150	Collect Data from Common Resource Locations	The library's CAPEC for T1530 and T1213	Inferred	[97]
CAPEC-664	Server Side Request Forgery	Capital One, only on the Reported SSRF basis; no ATT&CK mapping in the library	Inferred	[10][97]

The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	Id	Library mappings to this study's techniques	Guidance in the record it matches	Source
Multi-factor Authentication	D3-MFA	T1098.001, T1110.003, T1528, T1539, T1550.001, T1550.004, T1552, T1606	CSRB Lapsus$; Azure mandatory MFA; Snowflake MFA	[97][33][63][71]
Credential Rotation	D3-CRO	Same rows as D3-MFA	Codecov, CircleCI and Salesloft Drift rotation	[97][16][27][68]
Credential Revocation	D3-CR	Same rows as D3-MFA	Drift token revocation; Okta session token revocation	[97][68][36]
Authentication Cache Invalidation	D3-ANCI	Same rows as D3-MFA	Revoking stolen sessions at CircleCI and Okta	[97][27][36]
Credential Compromise Scope Analysis	D3-CCSA	Same rows as D3-MFA	Searching exfiltrated data for further secrets	[97][68]
Token Binding	D3-TB	T1528, T1550.001	Okta's network-bound admin sessions; the CSRB's session-bound tokens	[97][37][47]
Decoy User Credential	D3-DUC	Same rows as D3-MFA	AA24-057A canary service accounts	[97][45]
User Account Permissions	D3-UAP	T1078, T1078.002, T1078.004, T1087.004, T1098.003	Least privilege for service accounts; app-only permission audits	[97][45][43]
Access Modeling	D3-AM	T1078, T1078.002, T1078.004, T1087.004, T1098.003	Inventorying delegated trust (Inferred pairing)	[97]
User Geolocation Logon Pattern Analysis	D3-UGLPA	T1090.002, T1098.001, T1110.003, T1110.004, T1190, T1199, T1550.001, T1550.004, T1567	Snowflake network allow lists; Okta anonymizer blocking (Inferred pairing)	[97][53][44]
Web Session Access Mediation	D3-WSAM	T1621	Conditional Access app control (Inferred pairing)	[97][43]
Session Termination	D3-ST	T1199	Short session lifetimes in AA24-057A (Inferred pairing)	[97][45]
Configuration Inventory	D3-CI	T1114.003, T1490, T1526, T1538, T1552.005, T1578.002	SCuBA baselines and BOD 25-01 tenant inventory (Inferred pairing)	[97][64]
Restore Configuration	D3-RC	T1114.003, T1490, T1526, T1538, T1552.005, T1578.002	The library's only other row for T1552.005	[97]
Application Configuration Hardening	D3-ACH	T1114.003	IMDSv2 required; S3 Block Public Access (Inferred pairing)	[97][12][88]
Credential Scrubbing	D3-CS	No mapping to these techniques	Removing secrets from repositories and mail (Inferred pairing)	[97][35]

The library has no D3FEND rows for T1530 or T1606.002, and only Configuration Inventory and Restore Configuration for T1552.005, so no countermeasure in the library names IMDSv2 or metadata hop limits

directly (**Confirmed** [97]).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/cloud-security-incidents-2011-2026.json, listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 100 means a source in this study lists the id itself for a dated event; 75 means a primary describes the behavior and the id is this study's mapping; 40 means the only basis is Reported (T1552.005, whose dated use here rests on the Capital One reporting) or detection context only (T1685.002). T1190 scores 100 because Microsoft lists it for Storm-3168; its Capital One basis is Reported. Each entry's comment names the event and the source numbers in the table above. The library's topical cloud-attacks.json layer is a separate, broader view.

Cross-cutting themes

- **Identity is the perimeter the record keeps crossing.** From Dropbox's reused passwords in 2012 to Storm-0940's application identities in 2026, the opening move in most events here is a valid credential, token or app identity rather than a software exploit (**Inferred** from Parts 2 and 3). See the Identity Security Reference and the Identity and Access Management Reference.
- **Non-human identities outnumber human ones in the modern record.** OAuth apps, service accounts and principals, CI tokens, SAS tokens and integration roles recur from 2021 onward (**Inferred** from [68][37][27][35][76][80][82]).
- **Trust is transitive, and attackers know it.** Support contractors, CI vendors, SaaS integrations and MSP tools each turned one compromise into many (**Confirmed** [33][16][68][77]). The SolarWinds SUNBURST and XZ Utils backdoor studies show the software-supply-chain side of the same idea.
- **Logs decide what can be known.** Storm-0558 victims without premium logging could not see their own past; Okta's detection was slowed by an unexpected log event; the Entra ID Actor token flaw left no API-level log at all (**Confirmed** [47][37][70]).
- **Defaults move slowly, then all at once.** S3 public-block, IMDSv2, Azure MFA and Snowflake MFA all became defaults between 2023 and 2026, one to several years after the incidents that argued for them (**Confirmed** [88][12][63][71]).
- **Accountability reached the boardroom.** OCC penalties over migration risk, a proposed FTC order binding a CEO, SEC disclosure deadlines and charges against a CISO, and a CEO memo tying pay to security mark a shift from technical post-mortems to governance (**Confirmed** [9][26][32][38][51]).
- **Transparency is uneven.** Microsoft corrected its key-acquisition account months after learning it was wrong, and committed to cloud CVEs only in June 2024 (**Confirmed** [47][57]). Researchers and bug bounty programs remain the main public source of provider-side flaws (**Inferred** from [18][70][75]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	Dropbox, Security update and new features, Jul 2012	blog.dropbox.com/topics/company/security-update-new-features	2026-11-11	Confirmed
2	Dropbox, Resetting passwords to keep your files safe, 25 Aug 2016	blog.dropbox.com/topics/company/resetting-passwords-to-keep-your-files-safe	2026-11-11	Confirmed
3	FTC, Uber agrees to expanded settlement, 12 Apr 2018	`https://www.ftc.gov/news-events/news/press-releases/2018/04/uber-agrees-expanded-settlement-ftc-related-privacy-security-claims`	2026-11-11	Confirmed
4	UpGuard, Verizon cloud leak, 12 Jul 2017	upguard.com/breaches/verizon-cloud-leak	2026-11-11	Reported
5	UpGuard, Accenture cloud leak, 2017	upguard.com/breaches/cloud-leak-accenture	2026-11-11	Reported
6	UpGuard, CENTCOM and PACOM cloud leak, 17 Nov 2017	upguard.com/breaches/cloud-leak-centcom	2026-11-11	Reported
7	CISA, TA17-117A, Intrusions affecting multiple victims across multiple sectors, 27 Apr 2017, revised 20 Dec 2018	cisa.gov/news-events/alerts/2017/04/27/intrusions-affecting-multiple-victims-...	2026-11-11	Confirmed
8	Capital One, Information on the Capital One cyber incident	capitalone.com/digital/facts2019/	2026-11-11	Confirmed
9	OCC, News Release 2020-101, 6 Aug 2020	occ.gov/news-issuances/news-releases/2020/nr-occ-2020-101.html	2026-11-11	Confirmed
10	MITRE ATT&CK v20, T1552.005 Cloud Instance Metadata API (its citation of Capital One reporting is graded Reported)	attack.mitre.org/techniques/T1552/005/	2026-11-11	Confirmed; Reported for the Capital One path
11	AWS Security Blog, Add defense in depth against open firewalls, reverse proxies, and SSRF vulnerabilities with enhancements to the EC2 Instance Metadata Service, 19 Nov 2019	aws.amazon.com/blogs/security/defense-in-depth-open-firewalls-...	2026-11-11	Confirmed
12	AWS What's New, Set IMDSv2 as default for new instance launches, 25 Mar 2024	aws.amazon.com/about-aws/whats-new/2024/03/set-imdsv2-default-new-instance-launches/	2026-11-11	Confirmed
13	MSRC, Access misconfiguration for customer support database, Jan 2020	microsoft.com/en-us/msrc/blog/2020/01/access-misconfiguration-for-customer-support-database	2026-11-11	Confirmed
14	CISA, AA21-008A, Detecting post-compromise threat activity in Microsoft cloud environments, 8 Jan 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-008a	2026-11-11	Confirmed
15	CISA, AA21-055A, Exploitation of Accellion File Transfer Appliance, 24 Feb 2021	cisa.gov/news-events/cybersecurity-advisories/aa21-055a	2026-11-11	Confirmed
16	Codecov, Bash Uploader security update, 15 Apr 2021	about.codecov.io/security-update/	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
17	CISA, Kaseya VSA supply-chain ransomware attack, 2 Jul 2021	cisa.gov/news-events/alerts/2021/07/02/kaseya-vsa-supply-chain-ransomware-attack	2026-11-11	Confirmed
18	MSRC, Update on vulnerability in the Azure Cosmos DB Jupyter Notebook feature, Aug 2021	microsoft.com/en-us/msrc/blog/2021/08/update-on-vulnerability-in-the-azure-cosmos-db-...	2026-11-11	Confirmed
19	Okta, Okta concludes its investigation into the January 2022 compromise (Canadian edition)	okta.com/en-ca/blog/company-and-culture/okta-concludes-its-investigation-...	2026-11-11	Confirmed
20	Okta, Okta concludes its investigation into the January 2022 compromise, Apr 2022	okta.com/blog/2022/04/okta-concludes-its-investigation-...	2026-11-11	Confirmed
21	Microsoft Security, DEV-0537 criminal actor targeting organizations for data exfiltration and destruction, 22 Mar 2022	microsoft.com/en-us/security/blog/2022/03/22/dev-0537-...	2026-11-11	Confirmed
22	Uber, Security update, Sep 2022	`https://www.uber.com/newsroom/security-update/`	2026-11-11	Confirmed
23	LastPass, Notice of recent security incident	`https://blog.lastpass.com/posts/notice-of-recent-security-incident`	2026-11-11	Confirmed
24	LastPass, Security incident update and recommended actions, 1 Mar 2023	`https://blog.lastpass.com/posts/2023/03/security-incident-update-recommended-actions`	2026-11-11	Confirmed
25	MSRC, Investigation regarding misconfigured Microsoft storage location, Oct 2022	microsoft.com/en-us/msrc/blog/2022/10/investigation-regarding-misconfigured-...	2026-11-11	Confirmed
26	FTC, Action against Drizly and its CEO for security failures, 24 Oct 2022	`https://www.ftc.gov/news-events/news/press-releases/2022/10/ftc-takes-action-against-drizly-its-ceo-james-cory-rellas-security-failures-exposed-data-25-million`	2026-11-11	Confirmed
27	CircleCI, Incident report for the January 4, 2023 security incident	circleci.com/blog/jan-4-2023-incident-report/	2026-11-11	Confirmed
28	US Treasury, Report on the financial sector's adoption of cloud services, 8 Feb 2023	home.treasury.gov/news/press-releases/jy1252	2026-11-11	Confirmed
29	MSRC, Microsoft mitigates China-based threat actor Storm-0558 targeting of customer email, Jul 2023	microsoft.com/en-us/msrc/blog/2023/07/microsoft-mitigates-china-based-threat-actor-storm-0558-...	2026-11-11	Confirmed
30	CISA and FBI, AA23-193A, Enhanced monitoring to detect APT activity targeting Outlook Online, 12 Jul 2023	cisa.gov/news-events/cybersecurity-advisories/aa23-193a	2026-11-11	Confirmed
31	Microsoft Security, Expanding cloud logging to give customers deeper security visibility, 19 Jul 2023	microsoft.com/en-us/security/blog/2023/07/19/expanding-cloud-logging-...	2026-11-11	Confirmed
32	SEC, Press release 2023-139, cybersecurity disclosure rules, 26 Jul 2023	`https://www.sec.gov/news/press-release/2023-139`	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
33	CSRB, Review of the attacks associated with Lapsus$ and related threat groups, 10 Aug 2023 (PDF)	cisa.gov/sites/default/files/2023-08/CSRB_Lapsus%24_508c.pdf	2026-11-11	Confirmed
34	MSRC, Results of major technical investigations for Storm-0558 key acquisition, 6 Sep 2023, addendum 12 Mar 2024	microsoft.com/en-us/msrc/blog/2023/09/results-of-major-technical-investigations-...	2026-11-11	Confirmed
35	MSRC, Exposure of internal information in a storage account due to an overly permissive SAS token, 18 Sep 2023	microsoft.com/en-us/msrc/blog/2023/09/microsoft-mitigated-exposure-of-internal-information-...	2026-11-11	Confirmed
36	Okta Security, Tracking unauthorized access to Okta's support system, 20 Oct 2023	sec.okta.com/articles/2023/10/tracking-unauthorized-access-oktas-support-system/	2026-11-11	Confirmed
37	Okta Security, Unauthorized access to Okta's support case management system: root cause and remediation, 3 Nov 2023	sec.okta.com/articles/2023/11/unauthorized-access-oktas-support-case-management-system-root-cause	2026-11-11	Confirmed
38	SEC, Press release 2023-227, charges against SolarWinds and its CISO, 30 Oct 2023	`https://www.sec.gov/newsroom/press-releases/2023-227`	2026-11-11	Confirmed
39	Microsoft On the Issues, Secure Future Initiative, 2 Nov 2023	blogs.microsoft.com/on-the-issues/2023/11/02/secure-future-initiative-...	2026-11-11	Confirmed
40	CISA and FBI, AA23-320A, Scattered Spider, 16 Nov 2023, revised 29 Jul 2025	cisa.gov/news-events/cybersecurity-advisories/aa23-320a	2026-11-11	Confirmed
41	CISA and FBI, AA23-158A, CL0P exploits MOVEit, 7 Jun 2023	cisa.gov/news-events/cybersecurity-advisories/aa23-158a	2026-11-11	Confirmed
42	MSRC, Microsoft actions following attack by nation state actor Midnight Blizzard, 19 Jan 2024	microsoft.com/en-us/msrc/blog/2024/01/microsoft-actions-following-attack-...	2026-11-11	Confirmed
43	Microsoft Threat Intelligence, Midnight Blizzard: guidance for responders on nation-state attack, 25 Jan 2024	microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-...	2026-11-11	Confirmed
44	Okta Security, HAR files incident closure, 8 Feb 2024	sec.okta.com/harfiles	2026-11-11	Confirmed
45	CISA and partners, AA24-057A, SVR cyber actors adapt tactics for initial cloud access, 26 Feb 2024	cisa.gov/news-events/cybersecurity-advisories/aa24-057a	2026-11-11	Confirmed
46	MSRC, Update on Microsoft actions following attack by nation state actor Midnight Blizzard, 8 Mar 2024	microsoft.com/en-us/msrc/blog/2024/03/update-on-microsoft-actions-...	2026-11-11	Confirmed
47	CSRB, Review of the Summer 2023 Microsoft Exchange Online intrusion, dated 20 Mar 2024 (PDF)	cisa.gov/sites/default/files/2025-03/CSRBReviewOfTheSummer2023MEOIntrusion508.pdf	2026-11-11	Confirmed
48	CISA, CSRB review of the Summer 2023 MEO intrusion (landing page)	cisa.gov/resources-tools/resources/CSRB-Review-Summer-2023-MEO-Intrusion	2026-11-11	Confirmed
49	DHS, Cyber Safety Review Board releases report on Microsoft Online Exchange incident, 2 Apr 2024	dhs.gov/news/2024/04/02/cyber-safety-review-board-releases-report-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
50	CISA, Emergency Directive 24-02	cisa.gov/news-events/directives/ed-24-02-...	2026-11-11	Confirmed
51	Microsoft, Prioritizing security above all else, 3 May 2024	blogs.microsoft.com/blog/2024/05/03/prioritizing-security-above-all-else/	2026-11-11	Confirmed
52	Microsoft Security, Security above all else: expanding Microsoft's Secure Future Initiative, 3 May 2024	microsoft.com/en-us/security/blog/2024/05/03/security-above-all-else-...	2026-11-11	Confirmed
53	Mandiant (Google Cloud Threat Intelligence), UNC5537 targets Snowflake customer instances for data theft and extortion, 10 Jun 2024	cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion	2026-11-11	Confirmed
54	CISA, Snowflake recommends customers take steps to prevent unauthorized access, 3 Jun 2024	cisa.gov/news-events/alerts/2024/06/03/snowflake-recommends-...	2026-11-11	Confirmed
55	AT&T, Form 8-K Item 1.05, filed 12 Jul 2024	`https://www.sec.gov/Archives/edgar/data/732717/000073271724000046/t-20240506.htm`	2026-11-11	Confirmed
56	Live Nation Entertainment, Form 8-K Item 8.01, filed 31 May 2024	`https://www.sec.gov/Archives/edgar/data/1335258/000133525824000081/lyv-20240520.htm`	2026-11-11	Confirmed
57	MSRC, Toward greater transparency: unveiling cloud service CVEs, 27 Jun 2024	microsoft.com/en-us/msrc/blog/2024/06/toward-greater-transparency-unveiling-cloud-service-cves	2026-11-11	Confirmed
58	CrowdStrike, Falcon update for Windows hosts: technical details, Jul 2024	crowdstrike.com/en-us/blog/falcon-update-for-windows-hosts-technical-details/	2026-11-11	Confirmed
59	Microsoft, Helping our customers through the CrowdStrike outage, 20 Jul 2024	blogs.microsoft.com/blog/2024/07/20/helping-our-customers-through-the-crowdstrike-outage/	2026-11-11	Confirmed
60	CISA, Widespread IT outage due to CrowdStrike update, 19 Jul 2024	cisa.gov/news-events/alerts/2024/07/19/widespread-it-outage-due-crowdstrike-update	2026-11-11	Confirmed
61	CrowdStrike, Falcon content update preliminary post incident report, 24 Jul 2024	crowdstrike.com/en-us/blog/falcon-content-update-preliminary-post-incident-report/	2026-11-11	Confirmed
62	CrowdStrike, Channel File 291 incident root cause analysis, 6 Aug 2024 (PDF)	crowdstrike.com/wp-content/uploads/2024/08/Channel-File-291-Incident-Root-Cause-Analysis-08.06.2024.pdf	2026-11-11	Confirmed
63	Azure Blog, Announcing mandatory multifactor authentication for Azure sign-in, 15 Aug 2024 (its 99.2 percent figure is graded Reported)	azure.microsoft.com/en-us/blog/announcing-mandatory-multi-factor-authentication-for-azure-sign-in/	2026-11-11	Confirmed
64	CISA, BOD 25-01, Implementing secure practices for cloud services, 17 Dec 2024	cisa.gov/news-events/directives/bod-25-01-implementing-secure-practices-cloud-services	2026-11-11	Confirmed
65	CISA, Secure Cloud Business Applications (SCuBA) project	cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
66	FedRAMP, FedRAMP 20x	fedramp.gov/20x/	2026-11-11	Confirmed
67	Google Threat Intelligence Group, The cost of a call: from voice phishing to data extortion, 4 Jun 2025, updated 5 Aug 2025	cloud.google.com/blog/topics/threat-intelligence/voice-phishing-data-extortion	2026-11-11	Confirmed
68	Google Threat Intelligence Group, Widespread data theft targets Salesforce instances via Salesloft Drift, 26 Aug 2025, updated 28 Aug 2025	cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift	2026-11-11	Confirmed
69	NVD, CVE-2025-55241 record (API)	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2025-55241	2026-11-11	Confirmed
70	Researcher disclosure, Obtaining Global Admin in every Entra ID tenant with Actor tokens, 17 Sep 2025	dirkjanm.io/obtaining-global-admin-in-every-entra-id-tenant-with-actor-tokens/	2026-11-11	Confirmed
71	Snowflake documentation, MFA rollout and single-factor password deprecation	docs.snowflake.com/en/user-guide/security-mfa-rollout	2026-11-11	Confirmed
72	Microsoft Trust Center, Secure Future Initiative	microsoft.com/en-us/trust-center/security/secure-future-initiative	2026-11-11	Confirmed
73	CISA, Microsoft Expanded Cloud Logs Implementation Playbook (revision 1 May 2026)	cisa.gov/resources-tools/resources/microsoft-expanded-cloud-logs-implementation-playbook	2026-11-11	Confirmed
74	Microsoft Security, Passkey-themed social engineering leads to identity and cloud compromise, 9 Sep 2026	microsoft.com/en-us/security/blog/2026/09/09/passkey-themed-social-engineering-...	2026-11-11	Confirmed
75	Cloudflare, Cross-tenant vulnerability in Cloudflare Containers, Sep 2026	blog.cloudflare.com/containers-cross-tenant-vulnerability/	2026-11-11	Confirmed
76	Microsoft Security, Storm-3168: Agentic-driven cloud attacks using compromised service principals, 25 Sep 2026	microsoft.com/en-us/security/blog/2026/09/25/storm-3168-...	2026-11-11	Confirmed
77	Microsoft Security, Storm-0940 uses ARTEX agentic AI in ConnectWise supply chain compromise, 21 Oct 2026	microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-...	2026-11-11	Confirmed
78	ConnectWise, Trust Center advisories (Cloud Backup), first published 16 Oct 2026	connectwise.com/company/trust/advisories	2026-11-11	Confirmed
79	CyberScoop, Microsoft attributes ConnectWise supply chain attack to China's Storm-0940, 21 Oct 2026	cyberscoop.com/microsoft-attributes-connectwise-supply-chain-attack-china-storm-0940/	2026-11-11	Reported
80	Wiz, Qubole cross-account access abused in the wild, 9 Nov 2026	wiz.io/blog/qubole-cross-account-access-abused-in-the-wild	2026-11-11	Confirmed
81	Fireworks AI, October 2026 security incident update, 9 Nov 2026	fireworks.ai/security/bulletins/october-2026-security-incident-update	2026-11-11	Confirmed
82	Todyl, Stolen app credentials, real access: an actor is signing into Entra ID and Azure DevOps as your workloads, 3 Nov 2026, updated 6 Nov 2026	todyl.com/blog/stolen-app-credentials-real-access-...	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
83	BleepingComputer, N-able takes cloud platform offline after 30-plus zero-days published, 9 Nov 2026	bleepingcomputer.com/news/security/n-able-takes-cloud-platform-offline-...	2026-11-11	Reported
84	BleepingComputer, Hackers exploit trusted AWS access to breach multiple cloud environments, 10 Nov 2026	bleepingcomputer.com/news/security/hackers-exploit-trusted-aws-access-...	2026-11-11	Reported
85	Infosecurity Magazine, ASOS customers message about suspected compromise, 6 Oct 2026	infosecurity-magazine.com/news/asos-customers-message-suspected/	2026-11-11	Reported
86	CISA, Known Exploited Vulnerabilities catalog, version 2026.11.10 (JSON)	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
87	AWS What's New, Announcing AWS CloudTrail, 13 Nov 2013	aws.amazon.com/about-aws/whats-new/2013/11/13/announcing-aws-cloudtrail/	2026-11-11	Confirmed
88	AWS News Blog, Heads-up: Amazon S3 security changes are coming in April of 2023, 13 Dec 2022, updated 27 Apr 2023	aws.amazon.com/blogs/aws/heads-up-amazon-s3-security-changes-are-coming-in-april-of-2023/	2026-11-11	Confirmed
89	AWS, Shared responsibility model	aws.amazon.com/compliance/shared-responsibility-model/	2026-11-11	Confirmed
90	Microsoft Learn, Shared responsibility in the cloud (page date 24 Aug 2026)	learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility	2026-11-11	Confirmed
91	Google Cloud Architecture Framework, Shared responsibilities and shared fate	docs.cloud.google.com/architecture/framework/security/shared-responsibility-shared-fate	2026-11-11	Confirmed
92	AWS Organizations User Guide, Service control policies	docs.aws.amazon.com/organizations/latest/userguide/orgs_manage_policies_scps.html	2026-11-11	Confirmed
93	Amazon GuardDuty User Guide, GuardDuty IAM finding types	docs.aws.amazon.com/guardduty/latest/ug/guardduty_finding-types-iam.html	2026-11-11	Confirmed
94	MITRE ATT&CK v20, T1098.001 Additional Cloud Credentials	attack.mitre.org/techniques/T1098/001/	2026-11-11	Confirmed
95	MITRE ATT&CK v20, T1528 Steal Application Access Token	attack.mitre.org/techniques/T1528/	2026-11-11	Confirmed
96	TeamStarWolf Intelligence Hub, feed (used as an index of primary links only)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Inferred
97	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `d3fend_countermeasures.jsonl`, `data/attack/mobile/technique_profiles.jsonl`, `data/weaknesses/cwe.jsonl`, `data/weaknesses/capec.jsonl` and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
98	TeamStarWolf, Chronicle 2019 case study (Capital One section)	/case-studies/CHRONICLE_2019.md	2026-11-11	Inferred

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Cloud Security Reference, Cloud Attack Reference, Cloud Architecture Reference, Cloud, SaaS and Mobile Forensics Reference, Cloud Security Benchmark
- Identity Security Reference, Identity and Access Management Reference, Investigate a Cloud Compromise
- Threat Actors, Malware Families, Notable Incidents, CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Case studies: Chronicle 2019, Chronicle 2020, Chronicle 2021, SolarWinds SUNBURST, Cl0p and file transfer, Change Healthcare 2024, Healthcare Threat Watchlist, Threat Actors: Russia, Threat Actors: China, npm supply chain attacks, Hugging Face supply chain, XZ Utils backdoor, AI threats, Log4Shell, APT41 public record, Stuxnet, ICS attacks and advisories 2024 to 2026, The FireEye Mandiant Intrusion of 2020, The Ransomware Ecosystem, Able2Shell and the RMM Attack Surface, PHP2Shell and the October 2026 Attack Wave
- Series: 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025
- Groups: G0016 APT29, G1004 LAPSUS$, G1015 Scattered Spider, G1057 ShinyHunters, G0092 TA505
- Campaigns: C0024 SolarWinds Compromise, C0027, C0059 Salesforce Data Exfiltration
- Software: S0013 PlugX, S0153 RedLeaves
- Techniques: T1078.004 Cloud Accounts, T1552.005 Cloud Instance Metadata API, T1528 Steal Application Access Token, T1550.001 Application Access Token, T1199 Trusted Relationship, T1110.003 Password Spraying, T1606 Forge Web Credentials, T1114.002 Remote Email Collection, T1530 Data from Cloud Storage, T1685.002 Disable or Modify Cloud Log
- CAPEC: CAPEC-560, CAPEC-565, CAPEC-593, CAPEC-196
- Navigator layers, including this study's layer, cloud-security-incidents-2011-2026.json